

**HỌC VIỆN CÔNG NGHỆ BƯU CHÍNH VIỄN THÔNG
KHOA AN TOÀN THÔNG TIN**



**BÁO CÁO BÀI TẬP LỚN
HỌC PHẦN: PHÂN TÍCH MÃ ĐỘC
MÃ HỌC PHẦN: INT14164**

ĐỀ TÀI: HỆ THỐNG PHÁT HIỆN MÃ ĐỘC

Các sinh viên thực hiện :

Phạm Đăng Huy: B22DCAT148

Đặng Công Chúc: B19DCAT024

Hoàng Anh Khoa: B22DCAT164

Nguyễn Thị Quỳnh Trang: B22DCAT300

Trương Đức Thành: B22DCAT284

Tên nhóm: 01

Tên lớp: 04

Giảng viên hướng dẫn: PGS.TS Đỗ Xuân Chợt

HÀ NỘI 2025

PHÂN CÔNG NHIỆM VỤ NHÓM THỰC HIỆN

TT	Công việc / Nhiệm vụ	SV thực hiện	Thời hạn hoàn thành
1	Phân tích tĩnh và thực hành viết YARA rules quét mã độc có cơ chế ngủ đông	Phạm Đăng Huy	10/11/2025
2	Trích xuất đặc trưng file report và viết yara rule	Đặng Công Chúc	10/11/2025
3	Xây dựng phần mềm quét virus bằng YARA rule và tích hợp với hệ thống phân tích động cuckoo sandbox	Hoàng Anh Khoa	10/11/2025
4	Phân tích động, cài đặt và cấu hình cuckoo sandbox	Nguyễn Thị Quỳnh Trang	10/11/2025
5	Phân tích động và bổ sung YARA rules mới vào cơ sở dữ liệu	Trương Đức Thành	10/11/2025

NHÓM THỰC HIỆN TỰ ĐÁNH GIÁ

TT	SV thực hiện	Thái độ tham gia	Mức hoàn thành CV	Kỹ năng giao tiếp	Kỹ năng hợp tác	Kỹ năng lãnh đạo
1	Phạm Đăng Huy	5	5	5	5	
2	Đặng Công Chúc	5	5	5	5	
3	Hoàng Anh Khoa	5	5	5	5	
4	Nguyễn Thị Quỳnh Trang	5	5	5	5	5
5	Trương Đức Thành	5	5	5	5	

Ghi chú:

- Thái độ tham gia: Đánh giá điểm thái độ tham gia công việc chung của nhóm (từ 0: không tham gia, đến 5: chủ động, tích cực).
- Mức hoàn thành CV: Đánh giá điểm mức độ hoàn thành công việc được giao (từ 0: không hoàn thành, đến 5: hoàn thành xuất sắc).
- Kỹ năng giao tiếp: Đánh giá điểm khả năng tương tác, giao tiếp trong nhóm (từ 0: không hoặc giao tiếp rất yếu, đến 5: giao tiếp xuất sắc).
- Kỹ năng hợp tác: Đánh giá điểm khả năng hợp tác, hỗ trợ lẫn nhau, giải quyết mâu thuẫn, xung đột

- Kỹ năng lãnh đạo: Đánh giá điểm khả năng lãnh đạo (từ 0: không có khả năng lãnh đạo, đến 5: có khả năng lãnh đạo tốt, tổ chức và điều phối công việc trong nhóm hiệu quả).

MỤC LỤC

DANH MỤC CÁC HÌNH VẼ	5
DANH MỤC CÁC TỪ VIẾT TẮT	6
MỞ ĐẦU	8
CHƯƠNG 1. TỔNG QUAN	9
1.1 Đặt vấn đề.....	9
1.2 Ý tưởng.....	9
1.3 Kết chương	11
CHƯƠNG 2. NỀN TẢNG KIẾN THỨC	12
2.1 Tìm hiểu về mã độc.....	12
2.1.1 Khái niệm mã độc	12
2.1.2 Phân loại mã độc	13
2.1.3 Nguyên tắc hoạt động chung	14
2.1.4 Các định dạng dữ liệu nhiễm mã độc	16
2.1.5 Các công cụ rà quét và phương pháp phòng chống	19
2.2 Tìm hiểu phương pháp phân tích tĩnh	20
2.2.1 Khái niệm	20
2.2.2 Quy trình phân tích tĩnh	20
2.3 Tìm hiểu về phân tích động.....	34
2.3.1 Khái niệm phân tích động	34
2.3.2 Quy trình phân tích động	35
2.4 So sánh phương pháp phân tích tĩnh và phân tích động	51
2.4.1 Phân tích Tĩnh	51
2.4.2 Phân tích Động	52
2.4.3 So sánh giữa Phân tích Tĩnh và Phân tích Động	53
2.4.4 Kết luận	53
2.5 Kết chương	54
CHƯƠNG 3. THỬ NGHIỆM VÀ ĐÁNH GIÁ	55
3.1 Xây dựng ứng dụng.....	55
3.1.1 Khởi tạo và ghi log tệp tin quét	55
3.1.2 Gửi tệp tin lên Cuckoo Sandbox	57
3.2 Triển khai và thử nghiệm	59
3.2.1 Phân tích tĩnh cơ bản	63

3.2.2 Phân tích động	68
KẾT LUẬN.....	76
TÀI LIỆU THAM KHẢO	77

DANH MỤC CÁC HÌNH VẼ

Hình 1 Sơ đồ chung hệ thống	10
Hình 2 Các dạng mã độc	12
Hình 3 Sơ đồ chung phân tích tĩnh	21
Hình 4 Giao diện Pestudio	25
Hình 5 Trích xuất và phân tích hàm API	28
Hình 6 Phân tích chuỗi bằng công cụ Pestudio	30
Hình 7 Kiến trúc của Cuckoo Sandbox	36
Hình 8 Sơ đồ phân tích động của Cuckoo Sandbox	37
Hình 9 Khởi tạo và ghi log tệp tin quét	54
Hình 10 Vòng lặp for để kiểm tra danh sách trắng	55
Hình 11 Kiểm tra có khớp danh sách trắng không	56
Hình 12 Vòng lặp for kiểm tra danh sách đen	56
Hình 13 Trả về kết quả	57
Hình 14 Ghi log và gửi thông báo	57
Hình 15 Thiết lập API và header	58
Hình 16 Mở tệp tin và gửi yêu cầu POST	58
Hình 17 Kiểm tra kết quả phản hồi từ API	58
Hình 18 Xử lý lỗi khi gửi yêu cầu	58
Hình 19 Quét file Excel.exe	59
Hình 20 Quét file mã độc Ransomware.Petya	59
Hình 21 Hiện thị hành động sau khi phát hiện file mã độc	60
Hình 22 Chi tiết các chuỗi trùng với yara rule	60
Hình 23 Quét tệp unknown.exe	61
Hình 24 Gửi file lên cuckoo sandbox qua api thành công	61
Hình 25 Kết quả phân tích từ Cuckoo Sandbox đối với tệp tin	61
Hình 26 Các signature có mức độ nghiêm trọng cao của mã độc trích xuất trong file report.json	62
Hình 27 Danh sách địa chỉ bitcoin	63
Hình 28 Các công cụ mã độc sử dụng	63
Hình 29 Danh sách các hoạt động mạng	63
Hình 30 Imports trong Pestudio	65
Hình 31 Danh sách các hoạt động mạng	68
Hình 32 Danh sách các câu lệnh sử dụng	69
Hình 33 Danh sách các mutex mã độc sử dụng	73
Hình 34 Đoạn tin nhắn đáng ngờ	74
Hình 35 Các url liên quan đến bitcoin	74
Hình 36 Yararule sau khi phân tích và tổng hợp	74
Hình 37 Yararule sau khi phân tích và tổng hợp	75
Hình 38 Quét lại file Unknown	75

DANH MỤC CÁC TỪ VIẾT TẮT

STT	KÝ HIỆU	CHỮ VIẾT ĐẦY ĐỦ
1	PGS	PHÓ GIÁO SƯ
2	TS	TIẾN SĨ
3	GUI	GRAPHICAL USER INTERFACE
4	TT	THỨ TỰ
5	SV	SINH VIÊN
6	CV	CÔNG VIỆC
7	URL	UNIFORM RESOURCE LOCATOR
8	IP	INTERNET PROTOCOL
9	STT	SỐ THỨ TỰ
10	YARA	YET ANOTHER RIDICULOUS ACRONYM
11	USB	UNIVERSAL SERIAL BUS
12	PDF	PORTABLE DOCUMENT FORMAT
13	VPN	VIRTUAL PRIVATE NETWORK
14	IDS	INTRUSION DETECTION SYSTEM
15	SCA	SOFTWARE COMPOSITION ANALYSIS
16	MB	MEGABYTE
17	PE	PORTABLE EXECUTABLE
18	API	APPLICATION PROGRAMMING INTERFACE
19	DLL	DYNAMIC LINK LIBRARY
20	UPX	ULTIMATE PACKER FOR EXECUTABLES
21	ZIP	ZONE IMPROVEMENT PLAN
22	RAR	ROSHAL ARCHIVE
23	HTML	HYPERTEXT MARKUP LANGUAGE
24	PHP	HYPERTEXT PREPROCESSOR

25	CPL	CONTROL PANEL
26	VB	VISUAL BASIC
27	JAR	JAVA ARCHIVE
28	PID	PROCESS ID
29	ID	IDENTIFICATION
30	CPU	CENTRAL PROCESSING UNIT
31	PCAP	PACKET CAPTURE
32	TCP	TRANSMISSION CONTROL PROTOCOL
33	UDP	USER DATAGRAM PROTOCOL
34	HTTP	HYPERTEXT TRANSFER PROTOCOL
35	HTTPS	HYPERTEXT TRANSFER PROTOCOL SECURE
36	FTP	FILE TRANSFER PROTOCOL
37	DNS	DOMAIN NAME SYSTEM
38	SMB	SERVER MESSAGE BLOCK
39	IRC	INTERNET RELAY CHAT
40	APT	ADVANCED PERSISTENT THREAT
41	ICMP	INTERNET CONTROL MESSAGE PROTOCOL
42	SMTP	SIMPLE MAIL TRANSFER PROTOCOL
43	CD	COMPACT DISC
44	DVD	DIGITAL VERSATILE DISC
45	MSVCRT	MICROSOFT C RUNTIME LIBRARY
46	SCM	SERVICE CONTROL MANAGER
47	CMD	COMMAND PROMPT
48	WMIC	WINDOWS MANAGEMENT INSTRUMENTATION
49	BCD	BOOT CONFIGURATION DATA

MỞ ĐẦU

Phần mềm Antivirus là công cụ quan trọng trong việc bảo vệ các hệ thống máy tính trước các mối đe dọa từ phần mềm độc hại (malware). Các phương pháp truyền thống như phân tích tĩnh và phân tích động đã được sử dụng rộng rãi để phát hiện và ngăn chặn malware. Tuy nhiên, với sự phát triển không ngừng của các loại mã độc ngày càng tinh vi, một phương pháp phân tích kết hợp – kết hợp các ưu điểm của phân tích tĩnh và phân tích động – đang trở thành một xu hướng mới trong nghiên cứu và phát triển phần mềm antivirus.

Báo cáo bài tập lớn này tập trung vào việc nghiên cứu, thiết kế và xây dựng phần mềm antivirus dựa trên phương pháp phân tích kết hợp, hướng đến việc cải thiện khả năng phát hiện malware và tăng cường hiệu quả bảo vệ hệ thống. Báo cáo được tổ chức với các nội dung chính như sau:

Chương 1: Nghiên cứu tổng quan về vấn đề bằng cách nêu ra sự nguy hiểm của mã độc trong thời đại công nghệ phát triển với mạng lưới Internet phủ kín toàn cầu, từ đó đưa ra hướng giải quyết và nhu cầu cấp thiết trong việc tạo ra ứng dụng ngăn chặn mã độc. Nội dung bao gồm khái quát kiến thức các khái niệm cơ bản và vai trò của phương pháp phân tích kết hợp trong việc phát triển phần mềm antivirus, cơ chế phát hiện và tiêu diệt mã độc.

Chương 2: Phân tích nền tảng kiến thức. Nội dung bao gồm việc tìm hiểu sâu về các loại mã độc và phương pháp phân tích kết hợp gồm phân tích tĩnh và phân tích động, quy trình phân tích từng loại và mô hình kiến trúc.

Chương 3: Thực nghiệm và đánh giá phần mềm antivirus. Nội dung bao gồm triển khai và chạy thử phần mềm trên hệ thống thử nghiệm, so sánh kết quả và đánh giá hiệu năng của phương pháp phân tích kết hợp trong việc phát hiện và xử lý malware.

- Báo cáo nhằm cung cấp một cái nhìn toàn diện về phương pháp phân tích kết hợp trong xây dựng phần mềm antivirus, đồng thời đóng góp vào việc nâng cao hiệu quả bảo mật hệ thống máy tính

CHƯƠNG 1. TỔNG QUAN

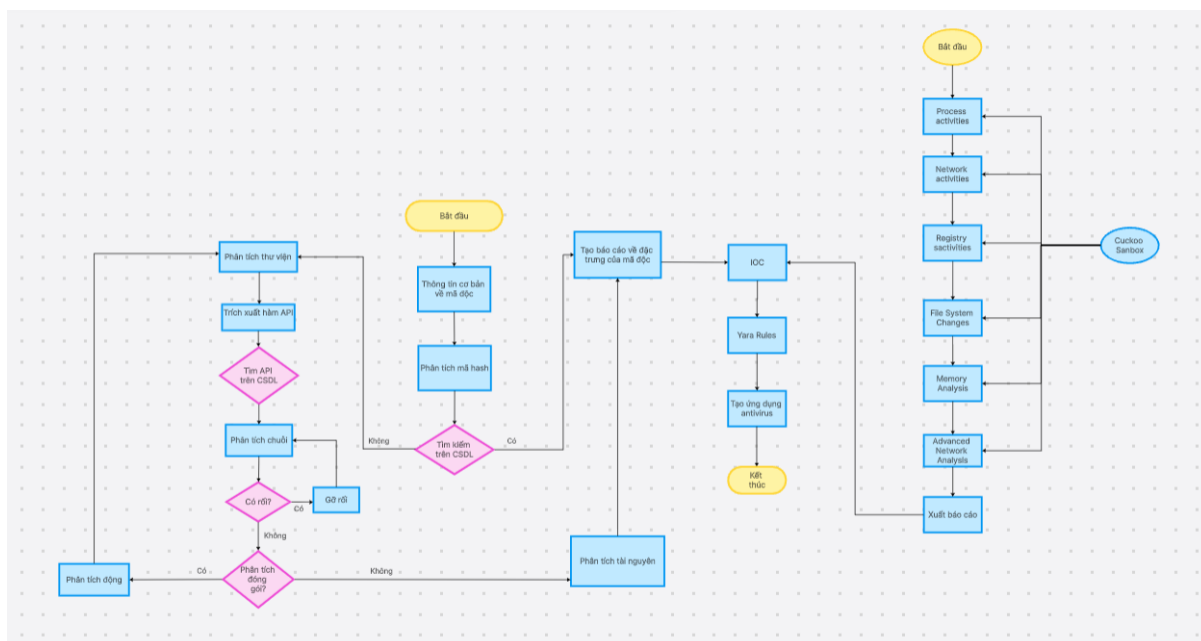
1.1 Đặt vấn đề

Trong thời đại kỹ thuật số ngày nay, sự phát triển nhanh chóng của công nghệ thông tin đi kèm với sự gia tăng đáng kể của các mối đe dọa an ninh mạng, đặc biệt là mã độc (malware) đã đặt ra thách thức lớn cho các cá nhân, tổ chức và chính phủ trong việc bảo vệ thông tin và duy trì sự an toàn trên không gian mạng. Mã độc có thể xâm nhập vào hệ thống thông qua nhiều hình thức khác nhau như email lừa đảo, phần mềm tải từ các nguồn không an toàn, hoặc qua các lỗ hổng bảo mật chưa được vá. Những mối đe dọa này không chỉ làm gián đoạn hoạt động mà còn có thể gây tổn thất tài chính nghiêm trọng, mất mát dữ liệu, và thậm chí đe dọa đến sự an toàn quốc gia. Mã độc không chỉ gây ra thiệt hại về mặt kinh tế mà còn đe dọa đến an toàn thông tin cá nhân và tổ chức. Vì vậy, nhu cầu về các phần mềm antivirus với khả năng phát hiện và ngăn chặn mã độc một cách nhanh chóng, chính xác trở nên cấp thiết hơn bao giờ hết.

Một trong những cách tiếp cận hiệu quả để giải quyết vấn đề này là sử dụng kết hợp giữa phân tích tĩnh và phân tích động. Phân tích tĩnh cho phép phát hiện mã độc thông qua việc kiểm tra mã nguồn hoặc cấu trúc file mà không cần thực thi chương trình, trong khi phân tích động giám sát hành vi của chương trình khi nó chạy trong môi trường mô phỏng. Sự kết hợp giữa hai phương pháp này giúp tăng cường khả năng phát hiện mã độc tiềm ẩn, ngay cả khi mã độc được che giấu dưới nhiều hình thức tinh vi.

1.2 Ý tưởng

Dựa trên vấn đề bảo mật và nhu cầu phát hiện mã độc một cách hiệu quả nhóm báo cáo đề xuất xây dựng một ứng dụng antivirus có khả năng nhận diện mã độc bằng cách kết hợp hai phương pháp phân tích tĩnh và phân tích động. Ứng dụng này sẽ khai thác sức mạnh của mỗi phương pháp để trích xuất đặc trưng của các file mã độc và từ đó tạo ra các YARA rules, xây dựng cơ sở dữ liệu cho hệ thống nhận diện mã độc.



Hình 1 Sơ đồ chung hệ thống

Phân tích tĩnh là quá trình kiểm tra và đánh giá các file, chương trình mà không cần thực thi chúng. Ứng dụng sẽ kiểm tra cấu trúc nhị phân hoặc mã nguồn của các file để phát hiện các dấu hiệu mã độc. Trong phân tích tĩnh, hệ thống sẽ áp dụng một số kỹ thuật như:

Kiểm tra chữ ký số học (hash): So sánh hash của file với cơ sở dữ liệu mã độc đã biết. Việc này giúp phát hiện các mẫu mã độc đã có trong cơ sở dữ liệu một cách nhanh chóng.

Dò tìm mẫu mã độc: Hệ thống sẽ sử dụng các mẫu mã độc đã biết để quét các đoạn mã hoặc mẫu trong file. Điều này bao gồm các dấu hiệu như chuỗi mã độc, mã ngẫu nhiên, hoặc các chức năng thường thấy trong mã độc.

Tìm kiếm hàm nguy hiểm: Phân tích các hàm và thư viện trong mã nguồn của file để phát hiện các hàm nguy hiểm, như hàm có khả năng gây rò rỉ thông tin, ghi đè hệ thống, hoặc các hàm truy cập trái phép vào tài nguyên.

Phân tích tĩnh giúp sàng lọc các file nghi ngờ là mã độc trước khi tiến hành các bước kiểm tra chuyên sâu, tối ưu hóa thời gian xử lý và giảm bớt số lượng file cần phân tích động.

Phân tích động là quá trình thực thi file nghi ngờ trong một môi trường ảo hóa an toàn (như Cuckoo Sandbox) để quan sát hành vi của nó. Mục tiêu của phân tích động là phát hiện các hành vi đáng ngờ mà mã độc có thể thực hiện khi được chạy. Cụ thể, phân tích động sẽ ghi nhận và phân tích các hoạt động:

Truy cập trái phép vào tài nguyên hệ thống: Theo dõi xem file có thực hiện các hành vi truy cập vào các file hoặc tài nguyên hệ thống mà không có sự cho phép.

Gửi dữ liệu ra ngoài: Quan sát các hoạt động kết nối mạng hoặc truyền tải dữ liệu bất thường. Mã độc thường gửi dữ liệu ra ngoài để báo cáo cho các máy chủ điều khiển từ xa.

Thay đổi file hệ thống: Ghi nhận các hành vi thay đổi hoặc ghi đè các file quan trọng của hệ điều hành, nhằm phát hiện các tác động mà mã độc có thể gây ra, như ghi đè tệp thực thi, tệp cấu hình hoặc hệ điều hành.

Thực hiện các tác vụ ẩn: Xác định các hành vi nhằm trốn tránh các cơ chế bảo vệ của hệ thống hoặc để lại “cửa sau” nhằm kiểm soát hệ thống sau này.

Kết quả từ phân tích động sẽ cung cấp thông tin chuyên sâu về hành vi của file, giúp xác nhận hoặc phủ nhận kết quả từ phân tích tĩnh.

Dựa trên kết quả phân tích tĩnh và động, hệ thống sẽ trích xuất các đặc trưng nổi bật của mã độc và chuyển hóa chúng thành các YARA rules.

YARA rules là các quy tắc để nhận diện mã độc dựa trên mẫu mã, chuỗi dữ liệu, hoặc hành vi cụ thể, tạo ra một cơ sở dữ liệu dễ cập nhật và mở rộng. Mỗi YARA rule sẽ đại diện cho một mẫu mã độc cụ thể hoặc một nhóm các hành vi đáng ngờ, giúp phát hiện các mẫu mã độc mới một cách nhanh chóng.

Cơ sở dữ liệu YARA rules sẽ đóng vai trò như "bộ nhớ" cho hệ thống, cho phép ứng dụng antivirus phát hiện nhanh chóng các file có đặc trưng mã độc mà không cần phân tích lại từ đầu. Điều này giúp cải thiện hiệu suất và nâng cao khả năng phát hiện mã độc của hệ thống.

Với các YARA rules được tạo ra từ quá trình phân tích, hệ thống sẽ dần dần mở rộng cơ sở dữ liệu mã độc, tích lũy các đặc trưng mới. Cơ sở dữ liệu này có thể được cập nhật liên tục dựa trên các mẫu mã độc mới thu thập, đảm bảo rằng ứng dụng luôn có khả năng nhận diện những mẫu mã độc mới nhất.

Việc sử dụng cơ sở dữ liệu YARA rules còn giúp chia sẻ đặc trưng mã độc với các hệ thống khác, góp phần xây dựng mạng lưới bảo mật rộng hơn.

1.3 Kết chương

Chương 1 đã trình bày tổng quan về vấn đề nghiên cứu, bao gồm bối cảnh và tầm quan trọng của việc phát hiện và ngăn chặn mã độc trong thời đại kỹ thuật số. Đồng thời, chương cũng nêu rõ ý tưởng và phương pháp tiếp cận thông qua việc kết hợp phân tích tĩnh và phân tích động nhằm tăng cường khả năng nhận diện mã độc. Các kỹ thuật phân tích đã được đề xuất với mục tiêu tạo ra các YARA rules để xây dựng cơ sở dữ liệu nhận diện mã độc hiệu quả, đảm bảo khả năng phát hiện nhanh chóng và mở rộng trước các mối đe dọa ngày càng phức tạp.

Chương này đặt nền tảng cho các nội dung tiếp theo, trong đó sẽ đi sâu vào thiết kế và triển khai hệ thống, thử nghiệm hiệu quả của các phương pháp đã nêu, và đánh giá khả năng ứng dụng thực tế của hệ thống trong việc phát hiện và ngăn chặn mã độc.

CHƯƠNG 2. NỀN TẢNG KIẾN THỨC

2.1 Tìm hiểu về mã độc

2.1.1 Khái niệm mã độc

Mã độc (malware) là một loại phần mềm độc hại được phát triển với mục đích xâm nhập, gây hại, hoặc khai thác tài nguyên của hệ thống máy tính, mạng và người dùng mà không có sự đồng ý của chủ sở hữu. Mã độc có thể thực hiện các hành vi như phá hủy, đánh cắp hoặc thay đổi dữ liệu, chiếm quyền điều khiển hệ thống, theo dõi hành vi người dùng, hoặc làm gián đoạn hoạt động của máy tính và mạng. Mã độc được thiết kế để hoạt động âm thầm, ẩn mình trong hệ thống, và thường được sử dụng bởi các tin tặc hoặc tổ chức tội phạm mạng nhằm thu lợi bất chính, tiến hành tấn công mạng, hoặc thực hiện các hành vi phá hoại.



Hình 2 Các dạng mã độc

Mã độc có thể lây nhiễm vào hệ thống thông qua nhiều cách khác nhau, chẳng hạn như tải xuống các file từ internet, mở email lừa đảo, truy cập vào các trang web độc hại, hoặc qua các thiết bị ngoại vi như USB. Khi mã độc đã xâm nhập vào hệ thống, nó có thể tự nhân bản, lây lan sang các máy tính khác trong cùng mạng, hoặc tạo ra các điểm truy cập trái phép để hacker có thể điều khiển từ xa. Ngoài ra, mã độc thường được thiết kế để khó phát hiện và gỡ bỏ, sử dụng nhiều kỹ thuật tiên tiến để ẩn mình khỏi các phần mềm bảo mật và hệ thống chống virus.

2.1.2 Phân loại mã độc

- Virus:

Virus là một trong những loại mã độc lâu đời và phổ biến nhất. Nó được thiết kế để đính kèm vào các file, chương trình hoặc tài liệu hợp pháp, và kích hoạt khi file hoặc chương trình đó được mở hay chạy.

Virus thường cần sự tương tác từ người dùng để kích hoạt, ví dụ như mở một file bị nhiễm, từ đó mã độc sẽ bắt đầu tự nhân bản và lây lan sang các file khác trong cùng hệ thống.

Một số virus có khả năng phá hủy dữ liệu, làm hỏng hệ điều hành, hoặc gây rối hoạt động của máy tính, trong khi số khác chỉ đơn giản là tự sao chép nhưng vẫn tiêu tốn tài nguyên hệ thống, làm chậm tốc độ xử lý.

- Sâu (Worm):

Sâu có điểm tương đồng với virus ở khả năng tự sao chép, nhưng khác biệt ở chỗ sâu không cần phải đính kèm vào bất kỳ file hay chương trình nào để hoạt động.

Sâu có thể tự lây lan qua mạng mà không cần sự tương tác từ người dùng. Chúng thường khai thác các lỗ hổng bảo mật trong hệ thống mạng hoặc phần mềm để thâm nhập và lây nhiễm.

Một khi đã xâm nhập, sâu có thể tự sao chép và lan rộng sang các máy tính khác trong cùng mạng, gây ra tình trạng tắc nghẽn mạng hoặc thậm chí làm sập toàn bộ hệ thống.

- Trojan (Trojan Horse):

Trojan là loại mã độc được ngụy trang dưới dạng một phần mềm hợp pháp hoặc hữu ích, khiến người dùng tin tưởng và tải về, cài đặt.

Một khi Trojan đã được cài đặt vào hệ thống, nó có thể mở ra "cửa sau" (backdoor) cho phép hacker xâm nhập và kiểm soát máy tính từ xa mà không cần sự cho phép của người dùng.

Trojan không tự sao chép như virus hay sâu, nhưng nó có thể được sử dụng để tải về và cài đặt thêm mã độc khác, gây ra nhiều mối đe dọa bảo mật khác nhau.

- Ransomware:

Ransomware là một trong những loại mã độc nguy hiểm và tinh vi nhất.

Khi xâm nhập vào hệ thống, nó sẽ mã hóa toàn bộ dữ liệu của nạn nhân, khiến họ không thể truy cập vào file hoặc hệ thống của mình. Sau đó, kẻ tấn công sẽ yêu cầu nạn nhân trả một khoản tiền chuộc (thường là tiền ảo như Bitcoin) để nhận được khóa giải mã.

Nếu nạn nhân không trả tiền chuộc trong thời gian quy định, dữ liệu có thể bị xóa vĩnh viễn hoặc tiền chuộc sẽ tăng lên. Một số biến thể ransomware thậm chí còn nhắm vào các doanh nghiệp lớn, gây thiệt hại nghiêm trọng về tài chính và hoạt động kinh doanh.

- Spyware:

Spyware là một loại phần mềm gián điệp được thiết kế để lén lút theo dõi hành vi của người dùng mà không bị phát hiện.

Nó có thể ghi lại các hoạt động trên máy tính, thu thập thông tin như lịch sử trình duyệt, mật khẩu, thông tin cá nhân và thông tin tài chính.

Một số spyware còn có khả năng ghi lại thao tác bàn phím (keylogger) để lấy trộm mật khẩu và thông tin nhạy cảm khác. Thông tin này sau đó được gửi về cho kẻ tấn công, và có thể được sử dụng để xâm phạm tài khoản ngân hàng, đánh cắp danh tính, hoặc thực hiện các cuộc tấn công khác.

- Adware:

Adware là phần mềm tự động hiển thị quảng cáo trên máy tính của người dùng, thường dưới dạng pop-up hoặc các banner quảng cáo khi người dùng truy cập web. Adware không phải lúc nào cũng có mục đích gây hại, nhưng nhiều trường hợp nó được cài đặt kèm theo các phần mềm mà người dùng tải về mà không biết.

Adware có thể làm chậm hệ thống, gây phiền toái cho người dùng và thậm chí theo dõi thói quen duyệt web để hiển thị các quảng cáo phù hợp. Một số loại adware còn có thể chứa mã độc, gây ra rủi ro bảo mật cho hệ thống.

- Rootkit:

Rootkit là loại mã độc cực kỳ nguy hiểm và phức tạp, cho phép kẻ tấn công giành quyền truy cập vào hệ thống ở cấp độ quản trị viên mà không bị phát hiện.

Một khi rootkit đã được cài đặt, kẻ tấn công có thể thay đổi các cài đặt hệ thống, giám sát hoạt động người dùng, hoặc thậm chí cài đặt thêm các loại mã độc khác mà phần mềm bảo mật không thể phát hiện.

Rootkit hoạt động rất kín đáo và thường được ẩn sâu trong hệ điều hành, khiến việc phát hiện và gỡ bỏ nó trở nên vô cùng khó khăn.

Rootkit có thể được sử dụng để duy trì quyền truy cập lâu dài vào hệ thống mà người dùng không hề hay biết.

2.1.3 Nguyên tắc hoạt động chung

Nguyên tắc hoạt động của mã độc có thể chia thành ba giai đoạn chính, gồm xâm nhập, kích hoạt, và gây hại. Mỗi giai đoạn trong quá trình này đều có các cơ chế và kỹ thuật riêng, thường được thiết kế để vượt qua các biện pháp bảo vệ của hệ thống, nhằm đạt được mục đích cuối cùng của mã độc là gây thiệt hại cho người dùng hoặc chiếm quyền kiểm soát hệ thống.

- GD1: Giai đoạn xâm nhập:

Xâm nhập là giai đoạn đầu tiên trong quá trình hoạt động của mã độc, khi nó tìm cách thâm nhập vào hệ thống mục tiêu. Mã độc có nhiều phương thức khác nhau để lấy nhiễm, từ các kỹ thuật tinh vi đến các phương pháp lừa đảo cơ bản. Một số phương pháp xâm nhập phổ biến bao gồm:

- Phishing (Lừa đảo qua email): Đây là một trong những phương thức lây nhiễm phổ biến nhất. Kẻ tấn công gửi email lừa đảo đến người dùng, đính kèm các tệp tin hoặc liên kết độc hại. Khi người dùng mở tệp hoặc nhấp vào liên kết, mã độc sẽ được tải xuống máy tính.

- Khai thác lỗ hổng bảo mật (Exploit): Mã độc có thể khai thác các lỗ hổng bảo mật chưa được vá trong hệ điều hành hoặc phần mềm của hệ thống mục tiêu. Các lỗ hổng này cho phép mã độc xâm nhập vào hệ thống mà không cần sự tương tác từ người dùng. Kẻ tấn công thường sử dụng các bộ công cụ khai thác (exploit kits) để tự động hóa quá trình này.

- Thiết bị ngoại vi: Thiết bị USB hoặc các phương tiện lưu trữ di động khác cũng là một nguồn lây nhiễm mã độc. Kẻ tấn công có thể đặt mã độc trong các thiết bị này và chờ người dùng cắm vào hệ thống mục tiêu làm mã độc tự động khởi chạy.

- Tải về từ trang web độc hại: Người dùng vô tình tải về phần mềm hoặc tài liệu từ các trang web không đáng tin cậy, hoặc mã độc có thể được nhúng vào các trang web qua quảng cáo độc hại (malvertising). Khi người dùng truy cập trang web hoặc tải nội dung về máy, mã độc sẽ tự động được cài đặt.

Trong giai đoạn này, mã độc thường sử dụng các phương pháp ngụy trang để tránh bị phát hiện. Ví dụ, Trojan có thể được ẩn dưới dạng các tệp tin hoặc phần mềm trông có vẻ hợp pháp, đánh lừa người dùng cài đặt.

- GD2: Giai đoạn Kích hoạt:

Sau khi mã độc xâm nhập thành công vào hệ thống, nó không ngay lập tức hoạt động mà thường chờ một thời điểm hoặc điều kiện thích hợp để kích hoạt. Các cơ chế kích hoạt mã độc thường được thiết kế rất linh hoạt để tránh bị phát hiện quá sớm, và để tối đa hóa tác động của nó. Có ba cơ chế kích hoạt phổ biến:

- Kích hoạt ngay lập tức: Trong nhiều trường hợp, mã độc sẽ kích hoạt ngay sau khi xâm nhập vào hệ thống. Chẳng hạn, các loại ransomware có thể ngay lập tức bắt đầu mã hóa dữ liệu của nạn nhân ngay sau khi được cài đặt thành công.

- Kích hoạt theo điều kiện: Một số mã độc chỉ hoạt động khi thỏa mãn một số điều kiện nhất định. Điều này giúp mã độc ẩn mình lâu hơn trong hệ thống, tránh bị phát hiện quá sớm.

- Kích hoạt theo thời gian: Có những loại mã độc được lập trình để kích hoạt vào một ngày hoặc thời gian nhất định, chẳng hạn như vào một ngày cụ thể trong tháng, hoặc sau khi mã độc đã lây nhiễm vào hệ thống trong một khoảng thời gian nhất định. Đây là chiến lược giúp mã độc tồn tại lâu hơn trước khi bị phát hiện và làm giảm khả năng người dùng phát hiện ra nó ngay từ đầu.

Trong giai đoạn này, mã độc có thể thực hiện các hoạt động chuẩn bị để tạo điều kiện thuận lợi cho việc gây hại sau đó. Ví dụ, mã độc có thể tắt các chương trình bảo mật, thay đổi cài đặt hệ thống hoặc cài đặt thêm các thành phần phụ trợ để đảm bảo rằng nó sẽ không dễ dàng bị gỡ bỏ.

- GD3: Giai đoạn gây hại:

Sau khi mã độc được kích hoạt thành công, nó sẽ tiến hành thực hiện các hành vi gây hại dựa trên mục đích của kẻ tấn công. Các hoạt động này rất đa dạng, phụ thuộc vào loại mã độc và mục tiêu mà nó nhắm đến. Một số hành vi gây hại phổ biến bao gồm:

- Xóa hoặc phá hủy dữ liệu: Nhiều loại mã độc, đặc biệt là virus và sâu, được thiết kế để làm hỏng hoặc xóa dữ liệu của nạn nhân. Chúng có thể làm hỏng các file hệ thống, khiến máy tính không thể hoạt động hoặc xóa các tệp tin quan trọng của người dùng.
- Mã hóa dữ liệu (Ransomware): Ransomware là loại mã độc điển hình cho hành vi này. Sau khi được kích hoạt, ransomware sẽ tiến hành mã hóa toàn bộ hoặc một phần dữ liệu của nạn nhân. Sau đó, nó yêu cầu nạn nhân trả tiền chuộc để có thể khôi phục lại dữ liệu.
- Đánh cắp thông tin: Spyware, trojan và các loại mã độc tương tự thường được sử dụng để theo dõi và đánh cắp thông tin cá nhân, dữ liệu tài chính hoặc thông tin đăng nhập của nạn nhân. Chúng có thể ghi lại các thao tác bàn phím, chụp màn hình hoặc theo dõi lưu lượng truy cập mạng để lấy cắp dữ liệu nhạy cảm.
- Mở cửa sau (Backdoor): Một số loại mã độc, đặc biệt là trojan và rootkit, có mục đích tạo ra "cửa sau" trong hệ thống để kẻ tấn công có thể xâm nhập vào máy tính từ xa mà không cần sự cho phép của người dùng. Điều này cho phép kẻ tấn công duy trì quyền truy cập vào hệ thống trong thời gian dài mà không bị phát hiện, và thực hiện các hành vi như cài đặt thêm mã độc hoặc kiểm soát hệ thống từ xa.
- Tạo botnet: Một số mã độc, đặc biệt là sâu hoặc trojan, có thể biến máy tính của nạn nhân thành một phần của mạng lưới botnet. Các máy tính bị nhiễm sẽ được kẻ tấn công điều khiển từ xa và sử dụng để thực hiện các cuộc tấn công mạng, gửi spam hoặc thực hiện các hoạt động phi pháp khác mà người dùng không hề hay biết.

2.1.4 Các định dạng dữ liệu nhiễm mã độc

Mã độc có thể nhắm tới nhiều định dạng dữ liệu khác nhau để lây nhiễm vào hệ thống, gây hại hoặc chiếm quyền điều khiển. Tùy thuộc vào cách mã độc được thiết kế, nó có thể lợi dụng lỗ hổng trong các file hoặc dữ liệu của các ứng dụng phổ biến mà người dùng thường tương tác. Dưới đây là các định dạng dữ liệu thường bị mã độc nhắm tới và cách thức mà mã độc khai thác chúng:

- File thực thi (.exe, .dll):

Các file thực thi là mục tiêu phổ biến của mã độc vì chúng có khả năng trực tiếp thay đổi hoặc điều khiển hệ thống máy tính khi được chạy. Hai loại chính trong nhóm này là file .exe và file .dll:

- File .exe (Executable): Đây là các chương trình hoặc phần mềm có khả năng thực thi mã lệnh trực tiếp trên hệ thống. Mã độc có thể được nhúng vào các file

.exe, đặc biệt là các phần mềm hoặc ứng dụng mà người dùng tải xuống từ các nguồn không đáng tin cậy. Khi người dùng chạy file .exe chứa mã độc, hệ thống sẽ bị lây nhiễm ngay lập tức.

- File .dll (Dynamic Link Library): File .dll chứa các thư viện mã và tài nguyên được sử dụng chung giữa các ứng dụng khác nhau. Mã độc có thể tấn công và thay đổi nội dung của các file .dll hoặc tạo ra các file .dll giả mạo để điều khiển hành vi của các ứng dụng.

Mã độc nhắm vào các file thực thi thường lợi dụng khả năng thực thi của chúng để kích hoạt mã độc mà không cần sự tương tác nhiều từ người dùng, khiến cho việc phòng chống trở nên khó khăn nếu không có biện pháp bảo vệ hệ thống tốt.

- Tài liệu (.docx, .pdf, .xls):

Các loại tài liệu văn phòng phổ biến như Microsoft Word, Excel hoặc PDF cũng là mục tiêu của mã độc, chủ yếu thông qua việc khai thác tính năng macro hoặc các lỗ hổng phần mềm:

- Macro độc hại: Macro là một tập lệnh tự động thực hiện các tác vụ trong tài liệu, đặc biệt là trong các file Word (.docx) hoặc Excel (.xls). Tin tặc có thể nhúng các macro độc hại vào tài liệu, và khi người dùng mở tài liệu và cho phép chạy macro, mã độc sẽ được kích hoạt. Thường được sử dụng trong các cuộc tấn công lừa đảo qua email, khi người dùng nhận được các tài liệu đính kèm trông có vẻ hợp pháp nhưng thực chất chứa mã độc.
- Khai thác lỗ hổng phần mềm đọc tài liệu: Các tài liệu PDF (.pdf) cũng thường là mục tiêu. Nếu phần mềm đọc PDF có lỗ hổng bảo mật, mã độc có thể được nhúng vào tài liệu PDF để khai thác lỗ hổng đó khi người dùng mở tài liệu. Khiến người dùng không cần thực hiện thêm hành động gì ngoài việc mở file cũng có thể bị lây nhiễm.

Các loại tài liệu này thường là phương tiện hữu ích cho các cuộc tấn công lừa đảo, vì chúng dễ dàng được gửi qua email hoặc tải xuống từ web, và người dùng thường tin tưởng vào tính hợp pháp của các file tài liệu quen thuộc.

- Email (.eml, .msg):

Email là một trong những kênh lây nhiễm mã độc phổ biến nhất, thường qua các file đính kèm hoặc liên kết độc hại. Mã độc có thể ẩn trong các file email (.eml hoặc .msg) hoặc qua các hình thức sau:

- File đính kèm độc hại: Email chứa các file đính kèm như file thực thi (.exe), tài liệu (.docx, .pdf), hoặc thậm chí là file nén (.zip) có thể chứa mã độc. Khi người dùng tải xuống và mở các file này mà không kiểm tra cẩn thận, mã độc sẽ tự động lây nhiễm vào hệ thống.
- Liên kết độc hại: Email cũng có thể chứa các liên kết tới các trang web độc hại. Khi người dùng nhấp vào liên kết, trình duyệt sẽ tự động tải xuống và chạy mã độc, hoặc sử dụng các lỗ hổng của trình duyệt để xâm nhập vào hệ thống.
- Phishing (Lừa đảo qua email): Nhiều cuộc tấn công mã độc sử dụng kỹ thuật lừa đảo qua email, trong đó kẻ tấn công giả mạo là một tổ chức hợp pháp để dụ người dùng nhấp vào liên kết hoặc mở file đính kèm. Các email này thường được thiết kế để trông giống với email thật từ ngân hàng, tổ chức chính phủ, hoặc doanh nghiệp mà người dùng có thể tin tưởng.

Email là phương thức phổ biến vì nó dễ dàng tiếp cận người dùng và có thể đánh lừa ngay cả những người dùng cẩn trọng nếu không có hệ thống bảo vệ hoặc biện pháp kiểm tra email chặt chẽ.

- Trang web (.html, .js):

Các trang web cũng là một phương tiện lây nhiễm mã độc rất phổ biến, đặc biệt thông qua mã JavaScript hoặc khai thác lỗ hổng của trình duyệt:

- Mã độc trong JavaScript (.js): Các trang web có thể chứa mã JavaScript độc hại. Khi người dùng truy cập trang web, mã này sẽ tự động chạy trong trình duyệt và có thể tải xuống các file mã độc hoặc khai thác lỗ hổng trình duyệt.
- Khai thác lỗ hổng trình duyệt: Các trình duyệt web thường xuyên có các lỗ hổng bảo mật, và mã độc có thể được thiết kế để khai thác những lỗ hổng này khi người dùng truy cập các trang web bị nhiễm.

- Drive-by download: Đây là một hình thức tấn công trong đó người dùng chỉ cần truy cập một trang web bị nhiễm, và mã độc sẽ tự động được tải xuống và chạy mà không cần sự đồng ý của người dùng.

Các trang web độc hại có thể dễ dàng được tạo ra hoặc lợi dụng qua các hình thức như quảng cáo giả mạo, hoặc tấn công các trang web phổ biến để chèn mã độc vào đó, khiến người dùng dễ dàng trở thành nạn nhân khi truy cập.

2.1.5 Các công cụ rà quét và phương pháp phòng chống

Mã độc ngày càng trở nên phức tạp và tinh vi, do đó các công cụ quét và phân tích mã độc đóng vai trò quan trọng trong việc phát hiện, ngăn chặn và loại bỏ chúng khỏi hệ thống. Dưới đây là các công cụ phổ biến và các giải pháp quét chuyên sâu trong việc phát hiện mã độc.

- Windows Defender:

Windows Defender là phần mềm chống virus tích hợp sẵn trên các hệ điều hành Windows. Với khả năng bảo vệ thời gian thực, nó liên tục quét các tệp và ứng dụng đang hoạt động, tìm kiếm và ngăn chặn các mối đe dọa tiềm ẩn. Windows Defender còn tích hợp các tính năng bảo mật như bảo vệ duyệt web, quản lý ứng dụng và bảo vệ trước ransomware. Dù không phải là giải pháp chống virus mạnh mẽ nhất trên thị trường, nhưng nhờ sự tiện lợi và khả năng bảo vệ cơ bản, nó là lựa chọn phổ biến đối với người dùng Windows.

- Kaspersky:

Kaspersky là một trong những phần mềm chống virus uy tín và mạnh mẽ nhất, nổi tiếng với khả năng phát hiện mã độc hiệu quả thông qua các phương pháp phân tích hành vi và nhận dạng mẫu (signature-based detection). Ngoài ra, Kaspersky còn cung cấp các tính năng bảo mật nâng cao như quản lý mật khẩu, bảo vệ duyệt web, và VPN. Phần mềm này cũng hỗ trợ phân tích mã độc dạng ransomware và bảo vệ chống lại các cuộc tấn công có chủ đích.

- Malwarebytes:

Malwarebytes là một công cụ chuyên về việc phát hiện và loại bỏ mã độc dạng malware, spyware, adware, và trojan. Công cụ này không chỉ phát hiện và quét sâu các mối đe dọa tiềm ẩn mà còn có khả năng bảo vệ trong thời gian thực, ngăn chặn các phần mềm

độc hại xâm nhập. Malwarebytes được biết đến với tính năng quét chuyên sâu, có thể tìm ra những loại mã độc mà các phần mềm chống virus truyền thống không phát hiện được.

- **Norton:**

Norton là một phần mềm chống virus toàn diện, nổi bật với các tính năng bảo vệ nhiều lớp khỏi virus, ransomware, spyware, và các hình thức tấn công trực tuyến khác. Norton còn cung cấp dịch vụ VPN để bảo vệ quyền riêng tư trực tuyến và công cụ quản lý mật khẩu để giúp người dùng tăng cường an ninh cá nhân. Phần mềm này cũng hỗ trợ giám sát hoạt động mạng để phát hiện các cuộc tấn công từ bên ngoài.

- **Cuckoo Sandbox:**

Cuckoo Sandbox là một công cụ phân tích mã độc trong môi trường ảo, cho phép kiểm tra hành vi của phần mềm đáng ngờ trong một hệ thống ảo tách biệt. Công cụ này đặc biệt hữu ích trong việc phát hiện các hành vi ẩn hoặc không nhận diện của mã độc, như việc mở cửa sau, theo dõi hoạt động người dùng hoặc mã hóa dữ liệu. Cuckoo Sandbox giúp phân tích chi tiết các hành vi của mã độc mà các phần mềm chống virus thông thường không thể phát hiện kịp thời.

2.2 Tìm hiểu phương pháp phân tích tĩnh

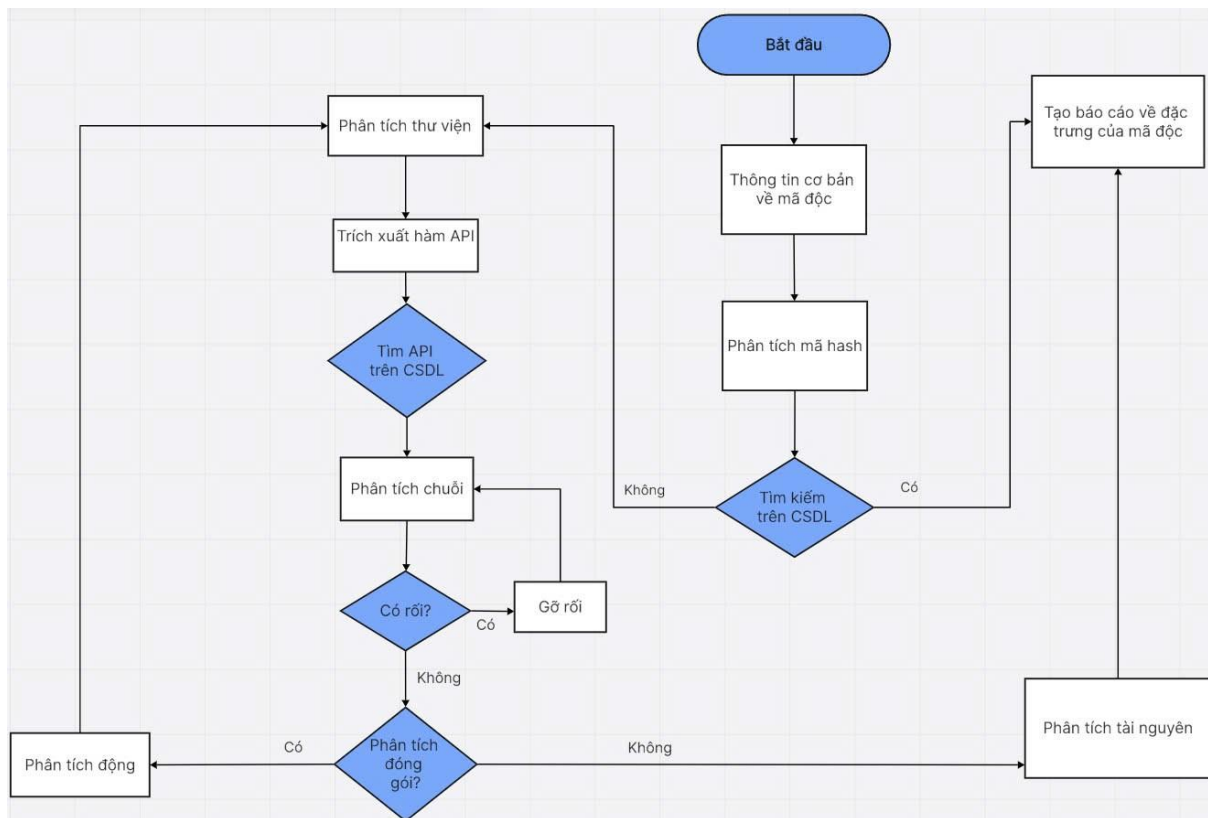
2.2.1 Khái niệm

Phân tích mã tĩnh bao gồm việc kiểm tra mã nguồn mà không cần thực thi. Nó cung cấp một phương tiện chủ động để xác định và khắc phục các sự cố ngay từ đầu vòng đời phát triển. Nó phân tích mã nguồn ứng dụng để tuân thủ các tiêu chuẩn mã hóa nhằm tăng khả năng đọc và bảo trì, tính chính xác về cú pháp và ngữ nghĩa, cũng như các lỗ hổng tiềm ẩn. Ngoài ra, nó thường được kết hợp với phân tích thành phần phần mềm (SCA). Các công cụ SCA sẽ kiểm tra kỹ lưỡng các thành phần của bên thứ ba để tìm các lỗ hổng tiềm ẩn, khả năng tuân thủ, quản lý phiên bản và quản lý phụ thuộc.

Đối với đề tài của nhóm, phương pháp phân tích tĩnh này được áp dụng bằng cách trích xuất các file đặc trưng có sẵn dựa trên cơ sở dữ liệu đã có để xây dựng lên bộ yara rules cho phần mềm, từ đó tăng tính khách quan trong quy trình quét mã độc.

2.2.2 Quy trình phân tích tĩnh

- **Sơ đồ phân tích tĩnh chung:**



Hình 3 Sơ đồ chung phân tích tĩnh

- Phân tích các bước:

• Lấy thông tin cơ bản về mã độc

Trước khi đi vào phân tích chi tiết mã độc, bước đầu tiên là kiểm tra thuộc tính cơ bản của file. Đây là một bước quan trọng và dễ thực hiện bằng cách sử dụng công cụ có sẵn trong hệ điều hành như Properties trên Windows. Thông qua việc phân tích các thuộc tính này, ta có thể nhận diện các dấu hiệu bất thường, phục vụ quá trình phát hiện mã độc. Dưới đây là những thuộc tính cần phân tích kỹ lưỡng:

○ Tên file, Product name, Copyright:

Tên file, tên sản phẩm (Product name), và bản quyền (Copyright) là các thuộc tính cơ bản được hiển thị trong phần Properties của file. Các thuộc tính này thường được mã độc giả mạo để đánh lừa người dùng. Cách nhận diện mã độc:

- Tên file giả mạo: Mã độc có thể mang những tên file phổ biến hoặc tương tự như các phần mềm hợp pháp để che giấu. Ví dụ, mã độc có thể được đặt

tên như explorer.exe (tên file hợp pháp của Windows Explorer), làm người dùng nhầm lẫn với một chương trình hợp lệ của hệ điều hành.

- Product name và Copyright: Mã độc cũng có thể giả danh các phần mềm có uy tín. Chúng có thể sử dụng thông tin về bản quyền hoặc tên sản phẩm của các công ty nổi tiếng như Microsoft, Nvidia, hoặc Adobe nhằm tạo sự tin cậy. Một số mã độc thậm chí sử dụng chữ ký số giả mạo để đánh lừa các phần mềm bảo mật.
- Kiểm tra nguồn gốc: Để kiểm tra xem file có thực sự thuộc về nhà phát hành đáng tin cậy hay không, có thể so sánh thông tin Product name và Copyright của file với thông tin từ trang web chính thức của nhà cung cấp phần mềm đó. Nếu phát hiện sự khác biệt hoặc nếu không có thông tin bản quyền rõ ràng, đây có thể là dấu hiệu của mã độc.

- Kích thước file:

Kích thước của file là một yếu tố quan trọng cần kiểm tra, vì mã độc thường có kích thước không đồng nhất với các phần mềm hợp lệ. Cách nhận diện mã độc:

- Mã độc giả mạo thường có kích thước không phù hợp với file gốc. Ví dụ, một file thực thi hợp lệ có thể có kích thước trong khoảng vài MB, nhưng file mã độc giả mạo có thể nhỏ hơn hoặc lớn hơn rất nhiều do tích hợp thêm các đoạn mã độc hoặc sử dụng kỹ thuật nén.
- So sánh kích thước file thực tế với thông tin từ các trang chủ chính thức của nhà phát hành phần mềm là một bước quan trọng. Nếu kích thước file nghi ngờ không khớp với kích thước file hợp pháp đã được công bố, có khả năng cao đây là một file mã độc.
- Ngoài ra, một số mã độc còn sử dụng các kỹ thuật nén hoặc đóng gói để thay đổi kích thước file nhằm che giấu sự hiện diện của mã độc. Trong những trường hợp này, các công cụ chuyên dụng có thể được sử dụng để giải nén file và kiểm tra các thành phần bên trong.

- Timestamp (thời gian sửa đổi):

Timestamp hay thời gian sửa đổi là một thuộc tính quan trọng khác giúp nhận diện mã độc. Nó cho biết thời điểm file được sửa đổi lần cuối. Mã độc thường có sự khác biệt giữa thời gian này với thời gian của các phiên bản phần mềm hợp lệ. Cách nhận diện mã độc:

- Thời gian sửa đổi của file nghi ngờ có thể không khớp với thời gian phát hành chính thức của phiên bản phần mềm gốc. Ví dụ, nếu file thuộc về một phần mềm được phát hành cách đây vài năm nhưng thời gian sửa đổi của file là gần đây, có khả năng file đã bị chỉnh sửa hoặc chứa mã độc.
- So sánh với thông tin chính thức: Bước này yêu cầu so sánh timestamp của file nghi ngờ với thông tin từ trang chủ hoặc cơ sở dữ liệu chính thức của nhà cung cấp phần mềm. Một file hợp lệ thường có timestamp trùng với thời điểm mà nhà phát hành công bố. Ngược lại, nếu thời gian sửa đổi là gần đây hoặc không khớp với phiên bản phần mềm, file đó có thể đã bị chỉnh sửa bởi kẻ tấn công.
- Timestamp giả mạo: Một số mã độc có thể cố gắng giả mạo timestamp bằng cách thay đổi giá trị này để tạo ra ấn tượng rằng file đã tồn tại từ lâu, nhưng qua việc so sánh với các mẫu hợp pháp, ta có thể nhận diện sự khác biệt.

● **Phân tích mã hash:**

Phân tích mã hash là một trong những bước quan trọng để nhận diện và phân loại mã độc một cách nhanh chóng và hiệu quả. Quá trình này giúp xác định xem mã độc có phải là một mẫu đã biết hay không, thông qua việc so sánh các giá trị hash với các mẫu trong cơ sở dữ liệu. Hashing không chỉ giúp nhận diện toàn bộ file mã độc mà còn có thể sử dụng để kiểm tra các phần khác nhau của file, chẳng hạn như header, thư viện, hoặc section trong cấu trúc PE.

○ **Tầm quan trọng của việc phân tích mã hash:**

- Nhận diện chính xác mã độc

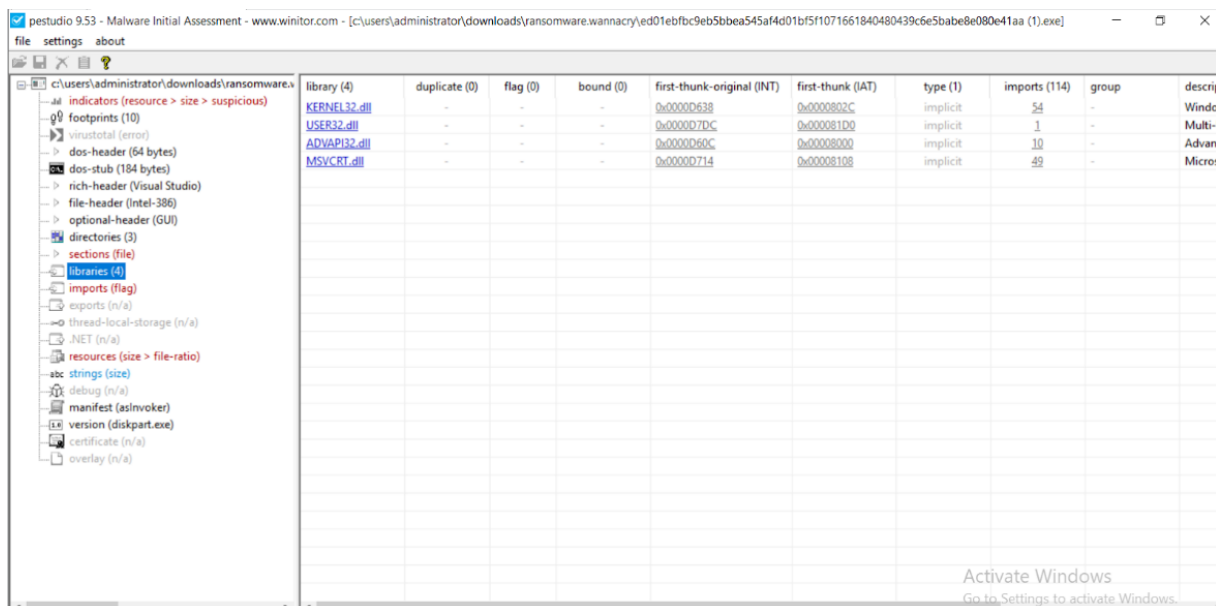
- Dễ dàng truy cập thông tin từ cộng đồng
- Tạo rule nhận diện mã độc
- **Các công cụ dùng để lấy mã hash:**
 - Md5sum, Sha256sum
 - Pestudio
- **Ứng dụng của phân tích hash:**
 - Xác minh tính toàn vẹn của file: So sánh mã hash của file hiện tại với mã hash gốc của nhà phát hành phần mềm sẽ giúp xác định xem file có bị thay đổi hoặc nhiễm mã độc không.
 - Phát hiện mã độc đã biết: Khi mã hash trùng với mã hash của một mẫu mã độc đã được nhận diện trong cơ sở dữ liệu có thể nhanh chóng đưa ra kết luận về file đang phân tích.
 - Theo dõi và chia sẻ thông tin: Việc sử dụng mã hash trong quá trình phân tích cũng giúp dễ dàng theo dõi và chia sẻ thông tin về các mẫu mã độc qua các cơ sở dữ liệu cộng đồng.

- **Phân tích thư viện:**

Trong quá trình phân tích tĩnh mã độc, một bước quan trọng là kiểm tra các thư viện (libraries) mà mã độc sử dụng. Các thư viện này cung cấp manh mối về các hành vi và mục tiêu của mã độc. Bằng cách phân tích những thư viện được mã độc sử dụng có thể dự đoán những hành động mà mã độc có khả năng thực hiện.

- **Tầm quan trọng của việc phân tích thư viện:**
 - Xác định hành vi mã độc
 - Dự đoán mục tiêu tấn công
- **Công cụ phân tích thư viện:**

Pestudio là một công cụ mạnh mẽ để phân tích các thư viện và hàm API mà mã độc sử dụng. Pestudio có một phần gọi là Libraries, hiển thị tất cả các thư viện mà mã độc gọi đến. Các thư viện này có thể được sử dụng để thực hiện các hành vi tấn công nhất định.



Hình 4 Giao diện Pestudio

○ Ứng dụng của phân tích thư viện:

- Dự đoán hành vi mã độc: Dựa vào các thư viện được phát hiện có thể nhanh chóng dự đoán hành vi của mã độc và đưa ra biện pháp đối phó. Ví dụ, nếu mã độc sử dụng nhiều thư viện liên quan đến thao tác với bộ nhớ, ta có thể tăng cường các biện pháp bảo vệ bộ nhớ hoặc giám sát các tiến trình hệ thống.
- Phân tích sâu hơn: Phân tích các thư viện giúp xác định các hàm cụ thể mà mã độc sử dụng, từ đó cung cấp manh mối về mục tiêu tấn công của mã độc. Việc biết chính xác các hàm nào được sử dụng giúp hiểu rõ hơn về chiến thuật và mục tiêu của kẻ tấn công.

● Trích xuất hàm API:

Trích xuất và phân tích hàm API là một bước quan trọng trong quá trình phân tích tĩnh mã độc. Các hàm API cung cấp cho mã độc quyền truy cập vào các chức năng và tài nguyên

của hệ điều hành, từ đó thực hiện các hành vi tấn công như thao tác với file, quản lý tiến trình, hoặc giao tiếp mạng. Phân tích hàm API giúp hiểu rõ cách mã độc tương tác với hệ thống và dự đoán các hành vi của nó.

- **Tầm quan trọng của việc phân tích hàm API:**

- Phát hiện hành vi tấn công
- Phân biệt giữa các hàm lành tính và độc hại

- **Công cụ phân tích hàm API:**

- Pestudio
- MalAPI.io

- **Phát hiện hành vi qua hàm API:**

- **Các hàm API thường thấy trong mã độc**

- CreateFile, WriteFile, ReadFile: Những hàm này cho phép mã độc tương tác với các file trên hệ thống, ví dụ như tạo, ghi hoặc đọc dữ liệu từ file. Đây là những hành động thường được sử dụng để ghi log hoặc tự nhân bản.
- OpenProcess, TerminateProcess: Các hàm này cho phép mã độc quản lý các tiến trình hệ thống, có thể điều khiển hoặc tắt tiến trình nhằm làm gián đoạn hoạt động của hệ điều hành hoặc các chương trình bảo mật.
- RegOpenKey, RegSetValue: Mã độc có thể sử dụng những hàm này để thao tác với registry của Windows, từ đó thay đổi cấu hình hệ thống hoặc tự động khởi động mỗi khi máy tính bật.

- **Khó khăn khi phân tích hàm API:**

- Sử dụng hàm API lành tính: Để làm khó các nhà phân tích, kẻ tấn công thường kết hợp các hàm lành tính vào mã độc. Các hàm này có thể không liên quan đến hành vi tấn công, nhưng vẫn được gọi để khiến mã độc trở

nên phức tạp và khó phân tích hơn. Điều này buộc các nhà phân tích phải phân loại và xác định mức độ rủi ro của từng hàm API.

- Các hàm API chưa có trong cơ sở dữ liệu: Đối với các hàm API chưa có thông tin trong các cơ sở dữ liệu mã độc, nhà phân tích phải dựa vào kinh nghiệm và kiến thức để xác định liệu hàm đó có độc hại hay không. Đây là một thử thách lớn, vì những mã độc mới thường chứa các hàm không phổ biến, buộc nhà phân tích phải sử dụng phương pháp disassembly để tìm hiểu.

○ **Phương pháp Disassembly:**

Disassembly là một phương pháp chuyển đổi mã nhị phân của một chương trình (thường là mã assembly) thành mã nguồn hoặc một dạng dễ hiểu hơn. Trong quá trình phân tích hàm API, nếu không thể xác định được hành vi của một hàm nào đó thì có thể sử dụng disassembly để xem mã chi tiết của hàm đó.

- **Cutter:** Cutter là một công cụ disassembly mạnh mẽ, giúp chuyển đổi mã assembly sang các ngôn ngữ bậc cao hơn. Cutter không chỉ hỗ trợ quá trình phân tích mã assembly mà còn cung cấp một cái nhìn tổng quan về quá trình gọi hàm API của mã độc, giúp hiểu rõ hơn về chức năng và vai trò của từng hàm trong cuộc tấn công.

○ **Ứng dụng của việc trích xuất và phân tích hàm API:**

- Xác định hành vi tấn công: Bằng cách phân tích các hàm API được mã độc sử dụng có thể dự đoán các hành vi tấn công như giao tiếp mạng, truy cập file, hoặc thay đổi cấu hình hệ thống.
- Tạo quy tắc phát hiện: Việc phân tích hàm API giúp các nhà phát triển phần mềm chống virus tạo ra các quy tắc nhận diện mã độc dựa trên các hàm độc hại mà mã độc sử dụng, giúp cải thiện khả năng phát hiện và ngăn chặn các cuộc tấn công.
- Dự đoán các kỹ thuật tấn công mới: Đối với các hàm API chưa có trong cơ sở dữ liệu, việc phân tích kỹ lưỡng có thể giúp phát hiện các kỹ thuật

tấn công mới mà mã độc sử dụng. Điều này có ý nghĩa lớn trong việc nâng cao khả năng phòng thủ và cập nhật cơ sở dữ liệu mã độc.

imports (114)	flag (14)	callback (0)	first-thunk-original (INT)	first-thunk-IAT	hint	group (10)	technique (11)
GetExitCodeProcess	x	-	0x0000D7F2	0x0000D7F2	346 (0x015A)	execution	-
TerminateProcess	x	-	0x0000D808	0x0000D808	862 (0x035E)	execution	-
CreateProcessA	x	-	0x0000D832	0x0000D832	102 (0x0066)	execution	T1106 Execution
SetCurrentDirectoryA	x	-	0x0000D882	0x0000D882	778 (0x030A)	-	-
WriteFile	x	-	0x0000D97E	0x0000D97E	932 (0x03A4)	file	-
SetFileAttributesW	x	-	0x0000D98A	0x0000D98A	794 (0x031A)	file	-
SetCurrentDirectoryW	x	-	0x0000D9D0	0x0000D9D0	779 (0x030B)	-	-
VirtualProtect	x	-	0x0000D836	0x0000D836	902 (0x0386)	memory	T1055 Process I
RegSetValueExA	x	-	0x0000D8F2	0x0000D8F2	516 (0x0204)	registry	T1112 Modify R
RegCreateKeyW	x	-	0x0000D0C4	0x0000D0C4	467 (0x01D3)	registry	T1112 Modify R
CryptReleaseContext	x	-	0x0000DC14	0x0000DC14	160 (0x00A0)	cryptography	T1027 Obfuscat
CreateServiceA	x	-	0x0000DC2A	0x0000DC2A	100 (0x0064)	services	T1543 Create or
rand	x	-	0x0000DCE6	0x0000DCE6	678 (0x02A6)	cryptography	T1027 Obfuscat
srand	x	-	0x0000DCEE	0x0000DCEE	692 (0x02B4)	cryptography	T1027 Obfuscat
CloseHandle	-	-	0x0000D7E4	0x0000D7E4	52 (0x0034)	-	-
WaitForSingleObject	-	-	0x0000D81C	0x0000D81C	912 (0x0390)	synchronization	-
GlobalFree	-	-	0x0000D944	0x0000D944	511 (0x01FF)	memory	-
GetProcAddress	-	-	0x0000D852	0x0000D852	416 (0x01A0)	dynamic-library	-
LoadLibraryA	-	-	0x0000D864	0x0000D864	594 (0x0252)	dynamic-library	T1106 Execution
GlobalAlloc	-	-	0x0000D874	0x0000D874	504 (0x01F8)	memory	-
GetCurrentDirectoryA	-	-	0x0000D89A	0x0000D89A	320 (0x0140)	execution	-
GetComputerNameW	-	-	0x0000D8B2	0x0000D8B2	279 (0x0117)	reconnaissance	T1082 System I
SetFileTime	-	-	0x0000D8C6	0x0000D8C6	799 (0x031F)	file	-
SetFilePointer	-	-	0x0000D8D4	0x0000D8D4	795 (0x031B)	file	-
MultiByteToWideChar	-	-	0x0000D8E6	0x0000D8E6	629 (0x0275)	-	-
GetFileAttributesW	-	-	0x0000D8FC	0x0000D8FC	353 (0x0161)	file	-
GetFileSizeEx	-	-	0x0000D912	0x0000D912	356 (0x0164)	-	-
CreateFileA	-	-	0x0000D922	0x0000D922	83 (0x0053)	-	-

Hình 5 Trích xuất và phân tích hàm API

• Phân tích chuỗi trong mã độc:

Phân tích chuỗi là một phương pháp quan trọng trong quá trình phân tích tĩnh mã độc. Việc trích xuất các chuỗi ký tự từ mã độc có thể giúp tìm ra những thông tin hữu ích như địa chỉ URL, tên miền, hàm API, hoặc các thông điệp được mã độc sử dụng trong quá trình thực thi. Phân tích chuỗi cũng cung cấp dữ liệu quan trọng cho việc viết Yara rule, giúp nhận diện các mẫu mã độc trong tương lai.

○ Ý nghĩa của phân tích chuỗi:

- Nhận diện thông tin cấu hình: Các chuỗi trong mã độc có thể chứa những thông tin nhạy cảm như địa chỉ máy chủ điều khiển và kiểm soát (C2), danh sách file mục tiêu, hoặc các chức năng mã độc. Phân tích chuỗi giúp phát hiện các dấu hiệu này và hiểu rõ hơn về mục tiêu của mã độc.
- Tạo dấu vết: Các chuỗi ký tự có thể là duy nhất hoặc dễ nhận diện, cho phép các nhà phân tích tạo ra chữ ký phát hiện hoặc rule Yara nhằm tự động hóa quá trình tìm kiếm mã độc tương tự trong tương lai.

○ **Khó khăn trong phân tích chuỗi:**

- Chuỗi bị làm rối (Obfuscation): Kẻ tấn công có thể làm rối mã nguồn và các chuỗi ký tự bên trong mã độc để giấu thông tin. Khi phân tích chuỗi bị làm rối, các công cụ như strings thường không thể trích xuất hoặc chỉ trích xuất được rất ít thông tin. Điều này khiến việc phân tích trở nên khó khăn và cần các công cụ hoặc phương pháp mạnh mẽ hơn để giải mã chuỗi.
- Dữ liệu bị đóng gói (Packing): Một số mã độc sử dụng kỹ thuật đóng gói để nén dữ liệu, bao gồm cả chuỗi ký tự, nhằm tránh bị phát hiện. Để phát hiện các chuỗi này, nhà phân tích cần phải giải nén mã độc trước khi thực hiện phân tích chuỗi.

○ **Cách nhận biết dữ liệu bị làm rối hoặc đóng gói:**

- Chuỗi ký tự bị làm rối: Khi các chuỗi bị làm rối, công cụ strings sẽ không trích xuất được nhiều thông tin có ý nghĩa, hoặc sẽ trích xuất ra các chuỗi ký tự vô nghĩa. Điều này là một dấu hiệu cho thấy mã độc có thể đã sử dụng kỹ thuật obfuscation.
- Dữ liệu bị đóng gói: Có thể nhận biết dữ liệu bị đóng gói bằng cách so sánh raw size và virtual size của các section trong tệp PE của mã độc:
 - ❖ $\text{Virtual size} = \text{Raw size}$: Đây là trường hợp bình thường.
 - ❖ $\text{Virtual size} > \text{Raw size}$: Section này có thể đã bị nén dữ liệu, một dấu hiệu cho thấy mã độc đã được đóng gói.
 - ❖ $\text{Virtual size} < \text{Raw size}$: Trường hợp hiếm gặp, cho thấy kẻ tấn công sử dụng kỹ thuật thao túng tệp PE để giấu dữ liệu.
- Entropy: Độ ngẫu nhiên (entropy) của dữ liệu là một chỉ số khác để xác định xem mã độc có bị đóng gói hay không. Nếu entropy cao, dữ liệu có thể đã bị nén hoặc mã hóa, do đó khả năng bị đóng gói là rất lớn.

○ **Giải nén dữ liệu đóng gói (Packing) sử dụng phân tích động:**

Khi chạy mã độc, nhiều loại mã độc sẽ tự động giải nén dữ liệu đã bị đóng gói. Quá trình phân tích động sẽ giúp quan sát được các tệp tin hoặc dữ liệu mà mã độc tự giải nén trong quá trình thực thi.

○ Quay lại phân tích sau giải nén và giải mã:

Sau khi giải nén dữ liệu hoặc giải mã chuỗi bị làm rối thì quay lại các bước phân tích trước đó như phân tích thư viện và phân tích API. Chuỗi ký tự và dữ liệu mới phát hiện có cái nhìn chính xác hơn về mã độc, từ đó xác định các hành vi tấn công và đặc trưng của nó.

○ Ý nghĩa của phân tích chuỗi đối với Yara rule:

Sau khi hoàn thành quá trình phân tích chuỗi, nhà phân tích có thể sử dụng các chuỗi ký tự quan trọng và duy nhất để tạo ra Yara rule. Các rule này giúp nhận diện mã độc dựa trên các chuỗi ký tự đặc trưng mà mã độc sử dụng. Đây là bước quan trọng trong việc phát hiện và ngăn chặn mã độc trong tương lai.

encoding (2)	size (bytes)	location	flag (28)	label (422)	group (11)	technique (16)	value (111594)
ascii	13	.data	x	import	services	T1543 Create or Modify System Proc...	CreateService
ascii	13	.data	x	import	registry	T1112 Modify Registry	RegSetValueEx
ascii	12	.data	x	import	registry	T1112 Modify Registry	RegCreateKey
ascii	19	.data	x	-	reconnaissance	-	GetNativeSyste
ascii	14	.data	x	import	memory	T1055 Process Injection	VirtualProtect
ascii	9	.data	x	import	file	-	WriteFile
ascii	17	.data	x	import	file	-	SetFileAttribut
ascii	9	.data	x	import	file	-	WriteFile
ascii	10	.data	x	-	file	T1485 Data Destruction	DeleteFile
ascii	10	.data	x	-	file	T1105 Remote File Copy	MoveFileEx
ascii	8	.data	x	-	file	T1105 Remote File Copy	MoveFile
ascii	18	.data	x	import	execution	-	GetExitCodePr
ascii	16	.data	x	import	execution	-	TerminateProc
ascii	13	.data	x	import	execution	T1106 Execution through API	CreateProcess
ascii	19	.data	x	import	cryptography	T1027 Obfuscated Files or Information	CryptReleaseC
ascii	4	.data	x	-	cryptography	T1027 Obfuscated Files or Information	rand
ascii	5	.data	x	-	cryptography	T1027 Obfuscated Files or Information	srand
ascii	11	.data	x	-	cryptography	T1027 Obfuscated Files or Information	CryptGenKey
ascii	12	.data	x	-	cryptography	T1027 Obfuscated Files or Information	CryptDecrypt
ascii	12	.data	x	-	cryptography	T1027 Obfuscated Files or Information	CryptEncrypt
ascii	15	.data	x	-	cryptography	T1027 Obfuscated Files or Information	CryptDestroyK
ascii	14	.data	x	-	cryptography	T1027 Obfuscated Files or Information	CryptImportKe
ascii	19	.data	x	import	-	-	CryptAcquireC
ascii	19	.data	x	import	-	-	SetCurrentDire
ascii	3	.xres	x	-	-	-	xmR
ascii	3	.xres	x	-	-	-	xmR
ascii	3	.xres	x	-	-	-	xmR

Hình 6 Phân tích chuỗi bằng công cụ Pestudio

● Phân tích tài nguyên (Resources):

Phân tích tài nguyên là một bước quan trọng trong việc phân tích tĩnh mã độc, đặc biệt là các mã độc có định dạng Portable Executable (PE). Tài nguyên (resources) trong cấu trúc

PE thường chứa các tệp dữ liệu mà mã độc sẽ sử dụng trong quá trình thực thi. Chúng có thể bao gồm hình ảnh, biểu tượng, tệp cấu hình, hoặc thậm chí là payloads bổ sung. Phân tích phần tài nguyên này giúp xác định các thành phần ẩn chứa hoặc các dữ liệu quan trọng mà mã độc sử dụng.

- **Mục đích phân tích tài nguyên:**

- Xác định dữ liệu bị ẩn: Tài nguyên trong mã độc có thể chứa các tệp hoặc dữ liệu cần thiết cho quá trình thực thi, như mã độc thứ cấp, thư viện mã độc, tệp tin cấu hình, hoặc các tệp mã hóa.
- Tìm kiếm các đặc trưng riêng biệt: Phân tích tài nguyên có thể giúp phát hiện các đặc trưng độc đáo của mã độc, chẳng hạn như biểu tượng (icon) của tệp hoặc các hình ảnh và tài liệu kèm theo, từ đó hỗ trợ trong việc nhận diện mã độc.

- **Phương pháp phân tích tài nguyên:**

- Mở đóng gói tài nguyên: Trước khi phân tích, phần tài nguyên trong mã độc thường bị đóng gói hoặc mã hóa. Sau khi thực hiện thành công các bước giải nén hoặc giải mã như đã thảo luận ở phần trước thì có thể tiến hành phân tích chi tiết phần tài nguyên này.
- Sử dụng công cụ Pestudio: Công cụ Pestudio có khả năng hiển thị phần resources trong cấu trúc PE của mã độc. Tại mục này có thể dễ dàng xem các tệp tài nguyên được mã độc sử dụng trong quá trình thực thi. Những tài nguyên này thường bị nén và giấu đi, nên sau khi giải nén có thể kiểm tra từng tệp một cách chi tiết.

- **Cách phân tích tài nguyên chi tiết:**

- Xem nội dung tài nguyên: Sử dụng Pestudio có thể phân tích section resources để xem các tệp tài nguyên có sẵn trong mã độc. Phần này sẽ liệt kê các loại tài nguyên khác nhau, bao gồm biểu tượng, menu, thư viện nhúng, và nhiều thành phần khác.

- So sánh với tệp hợp lệ: Một phương pháp phổ biến để phát hiện mã độc là so sánh các tài nguyên của tệp đáng ngờ với các tệp hợp lệ từ phần mềm chính thống. Ví dụ: một tệp hệ thống hợp lệ của Windows sẽ có biểu tượng và các phần tài nguyên trùng khớp với bản chính. Nếu mã độc giả danh tệp hệ thống mà không có tài nguyên tương tự, đây là dấu hiệu đáng nghi ngờ.
- Phân tích sâu bằng công cụ khác: Sau khi xác định các tệp tài nguyên trong mã độc thì có thể sử dụng các công cụ khác để phân tích chi tiết hơn, như Resource Hacker để xem chi tiết từng thành phần tài nguyên, hoặc Binwalk để trích xuất và phân tích các tệp tài nguyên đã bị đóng gói hoặc mã hóa.
- **Phát hiện tài nguyên đáng ngờ:**
 - Kích thước bất thường: Nếu các phần tài nguyên có kích thước bất thường (quá lớn hoặc quá nhỏ), đây có thể là dấu hiệu cho thấy chúng đã bị thay đổi hoặc chứa các payload ẩn.
 - Tài nguyên không liên quan: Một số mã độc có thể chứa các tài nguyên không liên quan hoặc không hợp lệ, ví dụ như một tệp có biểu tượng của phần mềm Microsoft nhưng lại chứa các thư viện DLL độc hại.
- **Phân tích đặc trưng của mã độc:**
 - **Phân tích cấu trúc mã nguồn:**
 - Mã độc được viết bằng ngôn ngữ nào? Cung cấp chi tiết về ngôn ngữ lập trình mà mã độc sử dụng như C, C++, Python, JavaScript.
 - Các chuỗi và hàm đặc trưng: Trích xuất các chuỗi ký tự (strings) trong mã nguồn, ví dụ: tên của các hàm, thông báo lỗi, thông điệp mã độc gửi tới máy chủ điều khiển. Những chuỗi này có thể là những đặc trưng để nhận diện khi tạo Yara rule.
 - **Tương tác với hệ thống:**

- Quyền truy cập hệ thống: Mã độc thường yêu cầu quyền quản trị hoặc quyền truy cập đặc biệt vào hệ thống. Có thể phát hiện các API gọi để thay đổi quyền truy cập hệ thống hoặc sửa đổi registry trên Windows.
- Cửa hậu và các hoạt động mạng: Tìm các đặc trưng mạng như kết nối với một địa chỉ IP ngoài tầm kiểm soát của hệ thống, gọi API để mở cổng hoặc kết nối đến máy chủ lạ. Các chuỗi và API liên quan đến các hoạt động mạng như connect, send, recv có thể được sử dụng trong Yara rule.

○ **Chữ ký và mã băm (hash signature):**

Mã băm tệp: Có thể trích xuất mã băm MD5, SHA1, hoặc SHA256 từ tệp tin mã độc đã được biết đến để tạo một chữ ký. Đây là cách nhanh chóng và chính xác để nhận diện mã độc khi nó chưa thay đổi.

○ **Che giấu và ẩn mình:**

- Mã hóa và nén: Mã độc thường mã hóa hoặc nén dữ liệu để tránh bị phát hiện. Bạn cần trích xuất các chuỗi hoặc dấu hiệu liên quan đến các kỹ thuật này như sử dụng mã hóa base64, hoặc các công cụ nén như UPX.
- Chạy ẩn: Mã độc có thể tự ẩn mình dưới dạng các tiến trình hệ thống hoặc ẩn trong các thư mục không rõ ràng. Tìm các dấu hiệu mã độc chạy ẩn bằng cách tìm kiếm các tiến trình hệ thống không xác định hoặc các tên tệp tin được ngụy trang.

○ **Kỹ thuật tấn công:**

- Lợi dụng lỗ hổng: Mã độc có thể khai thác lỗ hổng bảo mật trong hệ thống như các lỗ hổng zero-day hoặc lỗ hổng đã biết. Bạn có thể trích xuất các chuỗi liên quan đến việc khai thác các lỗ hổng này.
- Social engineering và phishing: Mã độc có thể được phân phối thông qua email phishing hoặc các trang web giả mạo. Bạn cần trích xuất các chuỗi liên quan đến các URL đáng ngờ hoặc các mẫu email có dấu hiệu phishing.

○ **Dấu hiệu hậu quả:**

- Lợi dụng lỗ hổng: Mã độc có thể khai thác lỗ hổng bảo mật trong hệ thống như các lỗ hổng zero-day hoặc lỗ hổng đã biết. Bạn có thể trích xuất các chuỗi liên quan đến việc khai thác các lỗ hổng này.
- Social engineering và phishing: Mã độc có thể được phân phối thông qua email phishing hoặc các trang web giả mạo. Bạn cần trích xuất các chuỗi liên quan đến các URL đáng ngờ hoặc các mẫu email có dấu hiệu phishing.

2.3 Tìm hiểu về phân tích động

2.3.1 Khái niệm phân tích động

- Định nghĩa

Phân tích động (Dynamic Analysis) là một kỹ thuật phân tích phần mềm được thực hiện trong quá trình phần mềm đang chạy, nhằm quan sát hành vi thực tế của phần mềm đó trong môi trường thực thi. Thay vì chỉ kiểm tra mã nguồn như trong phân tích tĩnh, phân tích động tập trung vào việc theo dõi các hành động mà chương trình thực hiện khi được cung cấp dữ liệu đầu vào thực tế. Kỹ thuật này rất hữu ích trong việc phát hiện các hành vi nguy hiểm hoặc bất thường mà mã độc (malware) có thể che giấu khi bị phân tích tĩnh.

Phân tích động thường bao gồm các hoạt động như:

- Theo dõi các hành vi truy cập tài nguyên (file, registry, mạng, bộ nhớ, v.v.).
- Kiểm tra các tương tác với hệ điều hành và các tiến trình khác.
- Đo lường hiệu năng và các tác động trong môi trường hệ thống thực tế.
- Xử lý các biến ẩn, mã độc tự thay đổi khi thực thi (polymorphic, metamorphic malware).

Kỹ thuật này thường được sử dụng khi phân tích tĩnh không đủ để phát hiện ra các mẫu hành vi đáng ngờ hoặc khi mã độc sử dụng các kỹ thuật ẩn mình phức tạp.

- Áp dụng phân tích động trong phần mềm antivirus của nhóm

Trong phần mềm **antivirus** của nhóm, phân tích động được áp dụng để phát hiện mã độc trong quá trình **quét file hoặc thư mục**. Cụ thể:

- **Phát hiện mã độc trong thời gian thực:** Khi người dùng chọn một file hoặc thư mục để quét, chương trình không chỉ kiểm tra nội dung của file dựa trên các mẫu tĩnh

(như các chữ ký mã độc thông qua các quy tắc YARA), mà còn kiểm tra các hành vi tiềm ẩn mà file đó có thể thực hiện khi được thực thi hoặc giải nén. Ví dụ:

- Giải nén các file nén và kiểm tra nội dung bên trong.
- Phát hiện các chuỗi mã hoặc hành vi nghi ngờ thông qua quá trình quét theo thời gian thực.
- **Xử lý các file nén và bảo vệ mật khẩu:** Phần mềm có khả năng giải nén và quét các file nén (như ZIP, RAR), và đây là một ứng dụng của phân tích động. Khi file nén được giải nén, các tệp bên trong sẽ được quét dựa trên quy tắc YARA để tìm mã độc. Điều này khác với phân tích tĩnh, chỉ đơn thuần là kiểm tra metadata hoặc nội dung nén ban đầu mà không thực sự giải nén để kiểm tra toàn diện.
- **Lý các hành động sau khi phát hiện mã độc:** Sau khi quét và phát hiện mã độc, phần mềm tác với các tác vụ thực thi dựa trên hành vi cụ thể của phần mềm.

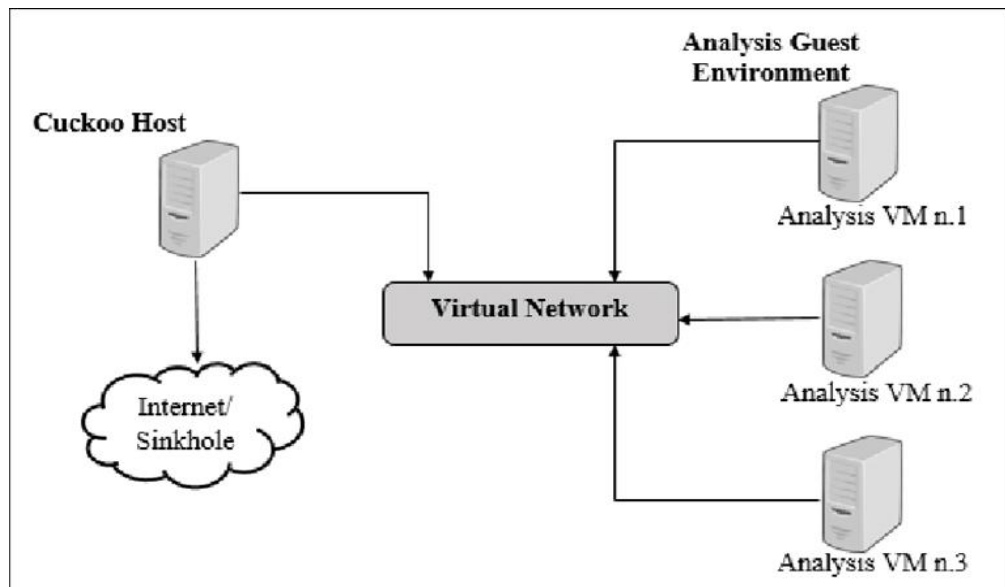
2.3.2 Quy trình phân tích động

- Tổng quan về cuckoo sandbox

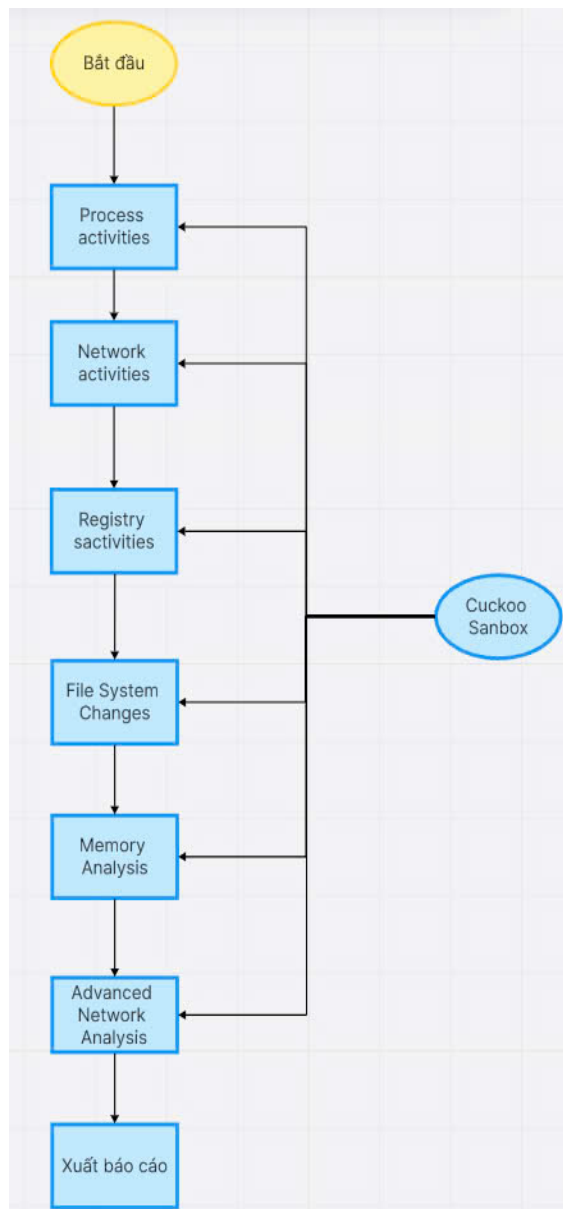
Cuckoo là một hệ thống phân tích phần mềm độc hại tự động mã nguồn mở.

Cuckoo Sandbox được sử dụng để tự động chạy và phân tích các tệp tin, đồng thời thu thập các kết quả phân tích toàn diện mô tả hành vi của phần mềm độc hại khi chạy trong một hệ điều hành cách ly. Được thiết kế để sử dụng như một ứng dụng độc lập hoặc tích hợp vào các hệ thống lớn hơn nhờ vào thiết kế cực kỳ mô-đun của nó. Nó có thể được sử dụng để phân tích: tệp thực thi Windows thông thường, tệp DLL, tài liệu PDF, Microsoft Office, URL, HTML, Script PHP, CPL, Script Visual Basic (VB), Tệp ZIP, Java JAR, Python, ...

Mỗi phân tích được khởi chạy trong một máy ảo hoặc máy vật lý mới và cách ly. Các thành phần chính của hạ tầng Cuckoo là máy Chủ (phần mềm quản lý) và một số máy Khách (máy ảo hoặc vật lý cho phân tích).



Hình 7 Kiến trúc của Cuckoo Sandbox



Hình 8 Sơ đồ phân tích động của Cuckoo Sandbox

- Quy trình phân tích động chung của các công cụ

• Phân tích hoạt động của tiến trình

Phân tích hoạt động của tiến trình (Process Activities) trong quy trình phân tích động của Cuckoo Sandbox là một phần cực kỳ quan trọng vì nó cung cấp cái nhìn sâu sắc về cách mã độc tương tác với hệ thống. Hoạt động này chủ yếu tập trung vào việc giám sát và ghi lại tất cả các lệnh gọi hệ thống và API mà mã độc thực hiện. Những lỗi trong việc phân tích hoạt động của một tiến trình. Khi mã độc được thực thi, nó sẽ tương tác với hệ điều hành thông qua các lệnh gọi API để thực hiện các tác vụ như tạo tệp, gửi hoặc nhận dữ liệu qua mạng, hoặc quản lý tài nguyên hệ thống.

Cuckoo Sandbox cài đặt các công cụ giám lệnh gọi này bao gồm các thao tác trực tiếp của mã độc với các tiến trình và hệ thống tệp, giúp xác định rõ ràng các hành động mã độc tiến hành trong quá trình thực thi:

- **Ghi lại các lệnh gọi API và hệ thống (Logging System Calls and API Calls)**

API Calls là một phần cốt lõi trong hệ thống, có thể là trong không gian nhân (kernel space) hoặc không gian người dùng (user space), để theo dõi mọi lệnh gọi API và hệ thống mà mã độc thực hiện. Ví dụ, khi mã độc cố gắng đọc hoặc ghi vào một tệp, gọi đến một dịch vụ mạng hoặc tạo một tiến trình mới, Cuckoo sẽ ghi lại chi tiết lệnh gọi đó.

Ví dụ các API thường bị lợi dụng:

- **CreateProcess / OpenProcess:** Tạo hoặc mở tiến trình mới.
- **WriteFile:** Đọc hoặc ghi vào tệp.
- **RegOpenKeyEx / RegSetValueEx:** Truy cập và thay đổi các khóa registry.
- **Send / Recv:** Gửi và nhận dữ liệu qua mạng.
- **CreateRemoteThread:** Tạo các luồng điều khiển từ xa trong các tiến trình khác, thường để tiêm mã độc.

- **Giám sát các tiến trình con (Monitoring Child Processes)**

Khi mã độc được thực thi, nó có thể tạo ra các **tiến trình con** (child processes) để phân chia các tác vụ, tạo sự phức tạp hoặc giấu giếm các hoạt động nguy hiểm:

- **CreateRemoteThread** là những lệnh gọi phổ biến được mã độc sử dụng để tạo tiến trình mới hoặc inject mã vào các tiến trình khác, từ đó có thể tránh bị phát hiện.
- Cuckoo Sandbox sẽ theo dõi các tiến trình con này và ghi lại các hoạt động của chúng giống như tiến trình chính. Mỗi tiến trình con sẽ được ghi lại với các chi tiết như: tên tiến trình, thời gian bắt đầu và kết thúc, PID (Process ID) của nó, lệnh gọi API mà tiến trình con thực hiện.

Việc giám sát tiến trình con giúp phát hiện những hành vi phức tạp của mã độc, đặc biệt khi nó cố gắng lẫn trốn thông qua việc chia nhỏ các hoạt động vào nhiều tiến trình.

- **Quản lý và thao tác với tiến trình khác (Interacting with Other Processes)**

- Mã độc thường cố gắng thao tác hoặc can thiệp vào các tiến trình khác trên hệ thống. Các hành vi này bao gồm mở, đọc và ghi vào các tiến trình khác

thông qua các lệnh gọi như `OpenProcess` và `WriteProcessMemory`. Đây là các kỹ thuật phổ biến để tiêm mã (code injection) vào các tiến trình khác hoặc chiếm quyền điều khiển của chúng.

- **Tiêm mã** là một kỹ thuật mà mã độc sử dụng để thực thi mã độc trong không gian của một tiến trình hợp pháp, nhằm tránh sự phát hiện của các hệ thống bảo mật. Ví dụ: **DLL Injection, Process Hollowing**.

Cuckoo Sandbox ghi lại tất cả các hoạt động này và tạo ra báo cáo chi tiết về mọi tiến trình mà mã độc tương tác. Nếu mã độc tiêm mã vào một tiến trình khác, Cuckoo sẽ xác định rõ ràng tiến trình nào bị tiêm, mã nào được tiêm, và hành vi của mã sau đó.

- **Ghi lại trạng thái tiến trình (Process State and Resource Usage)**

- Bên cạnh việc giám sát các lệnh gọi API và tiến trình con, Cuckoo cũng theo dõi trạng thái của tiến trình mã độc trong suốt quá trình thực thi. Các thông tin về sử dụng tài nguyên hệ thống như bộ nhớ, CPU, và quyền truy cập vào các tài nguyên khác được ghi lại.
- Điều này cho phép nhà phân tích phát hiện xem mã độc có gây tăng đột biến sử dụng tài nguyên hệ thống (một dấu hiệu của các cuộc tấn công DoS, hoặc việc khai thác tài nguyên máy để đào tiền ảo) hay không.

- **Phân tích hoạt động mạng**

Phân tích hoạt động mạng(Network Activities) trong quy trình phân tích động của Cuckoo Sandbox đóng vai trò quan trọng trong việc giám sát cách mà mã độc tương tác với mạng và các thiết bị từ xa. Thông qua việc ghi lại các lưu lượng mạng dưới định dạng PCAP (Packet Capture), công cụ này giúp nhà phân tích hiểu rõ cách thức mã độc truyền dữ liệu hoặc nhận chỉ thị từ các máy chủ điều khiển từ xa (C&C server):

- **Ghi lại các kết nối mạng (Logging Network Connections)**

Khi mã độc được thực thi, Cuckoo sẽ bắt đầu theo dõi tất cả các kết nối mạng mà tiến trình mã độc tạo ra hoặc tương tác. Mọi kết nối giữa hệ thống đang chạy mã độc và các máy chủ bên ngoài đều được ghi lại, bao gồm:

- Địa chỉ IP của các máy đích.
- Tên miền mà mã độc kết nối tới, nếu có.
- Cổng giao tiếp (ports) mà mã độc sử dụng cho các kết nối.

- Giao thức mạng (TCP, UDP, HTTP, HTTPS, FTP, v.v.).

- **Ghi lại lưu lượng mạng dưới định dạng PCAP (Network Traffic Capture in PCAP Format)**

Cuckoo Sandbox sử dụng công cụ packet sniffer (ví dụ như tcpdump) để ghi lại toàn bộ lưu lượng mạng giữa máy đang chạy mã độc và môi trường mạng bên ngoài dưới định dạng PCAP (Packet Capture).

PCAP là định dạng chuẩn để lưu trữ và phân tích các gói tin mạng. Các gói tin này bao gồm mọi thông tin về dữ liệu được gửi và nhận, như:

- **Thông tin gói tin:** địa chỉ nguồn và đích, giao thức mạng, cổng kết nối, chiều dài gói tin.
- **Payload:** nội dung của gói tin, giúp phân tích dữ liệu thực mà mã độc gửi hoặc nhận.

- **Phân tích các giao thức mạng (Network Protocol Analysis)**

Sau khi thu thập các gói tin trong định dạng PCAP, Cuckoo sẽ tiến hành phân tích các giao thức mà mã độc sử dụng. Điều này bao gồm các giao thức phổ biến như:

- **HTTP/HTTPS:** Mã độc thường sử dụng giao thức này để liên lạc với các máy chủ từ xa, đặc biệt khi muốn tải thêm tệp tin hoặc gửi dữ liệu bị đánh cắp.
- **DNS:** Mã độc có thể thực hiện các truy vấn DNS để phân giải tên miền thành địa chỉ IP, từ đó kết nối với máy chủ từ xa.
- **FTP/SMB:** Giao thức truyền tệp có thể được sử dụng để tải hoặc gửi các tệp dữ liệu độc hại.
- **IRC:** Một số mã độc sử dụng giao thức này để liên lạc với máy chủ điều khiển CnC trong các mạng botnet.

Phân tích giao thức giúp nhà phân tích hiểu rõ cách mã độc giao tiếp với mạng bên ngoài, cách thức mà nó truyền tải dữ liệu hoặc nhận lệnh từ máy chủ từ xa.

- **Giám sát và ghi lại các truy vấn DNS (DNS Query Monitoring)**

Truy vấn DNS là một phần quan trọng trong hoạt động mạng của mã độc. Trước khi mã độc có thể kết nối đến một máy chủ từ xa bằng tên miền (domain), nó phải thực hiện truy vấn DNS để phân giải tên miền thành địa chỉ IP. Cuckoo ghi lại toàn bộ các truy vấn DNS mà mã độc thực hiện, bao gồm:

- Tên miền mà mã độc cố gắng truy vấn.
- Địa chỉ IP mà tên miền phân giải thành.

Thông qua việc theo dõi truy vấn DNS, nhà phân tích có thể xác định liệu mã độc có đang cố gắng kết nối tới các máy chủ điều khiển (CnC) thông qua tên miền không. Điều này đặc biệt hữu ích trong việc phát hiện các chiến dịch tấn công tinh vi (Advanced Persistent Threat - APT) khi mã độc sử dụng các tên miền khó xác định hoặc bị mã hóa.

- **tích hoạt động của registry**

Phân tích hoạt động của registry(Registry Activities) trong phân tích động là một bước quan trọng khi giám sát các thay đổi mà mã độc thực hiện trên Windows Registry. Registry là một cơ sở dữ liệu lưu trữ các cấu hình, tùy chọn, và cài đặt hệ thống quan trọng của Windows, và cũng là một mục tiêu phổ biến mà mã độc tấn công để duy trì sự tồn tại hoặc thay đổi các thiết lập hệ thống:

● **Ghi lại các khóa Registry được tạo mới (Logging New Registry Keys)**

Khi mã độc được thực thi, một trong những hành vi phổ biến là tạo ra các khóa Registry mới để lưu trữ thông tin cần thiết cho việc thực thi lần sau hoặc để cài đặt các giá trị cấu hình độc hại.

Cuckoo Sandbox giám sát tất cả các khóa hoặc giá trị mới mà mã độc tạo ra trong Windows Registry. Điều này bao gồm việc theo dõi các khóa quan trọng mà mã độc có thể tạo để ẩn mình hoặc để khởi động tự động, chẳng hạn như:

- **HKEY_CURRENT_USER\Software\Microsoft\Windows\CurrentVersion\Run**
- **HKEY_LOCAL_MACHINE\Software\Microsoft\Windows\CurrentVersion\Run**

Ví dụ, mã độc có thể tạo một khóa trong mục Run để tự động khởi động mỗi khi người dùng đăng nhập vào hệ thống. Điều này giúp mã độc duy trì sự tồn tại trên hệ thống ngay cả khi người dùng khởi động lại máy tính.

- **Theo dõi các thay đổi trong các khóa hiện có (Monitoring Changes to Existing Registry Keys)**

Ngoài việc tạo khóa mới, mã độc cũng có thể thay đổi các khóa Registry hiện có để thay đổi hành vi hệ thống hoặc gây lỗi ứng dụng.

Cuckoo Sandbox sẽ giám sát mọi thay đổi mà mã độc thực hiện trên các giá trị của các khóa đã tồn tại từ trước. Các thay đổi này có thể bao gồm việc chỉnh sửa các khóa liên quan đến:

- **Cấu hình hệ thống:** Mã độc có thể thay đổi cấu hình hệ thống như thiết lập mạng, bảo mật, hoặc quyền hạn của người dùng để kiểm soát hệ thống.
- **Khóa khởi động:** Thay đổi các khóa để kích hoạt các chương trình độc hại khi khởi động hệ thống.

Ví dụ, mã độc có thể chỉnh sửa các khóa liên quan đến cấu hình bảo mật của hệ thống để vô hiệu hóa các biện pháp bảo vệ (như Windows Defender) hoặc thay đổi quyền hạn của tài khoản người dùng để dễ dàng thực hiện các hành vi độc hại.

- **Ghi lại các hoạt động xóa khóa Registry (Logging Deletions of Registry Keys)**

Một hành vi phổ biến khác là mã độc xóa bỏ một số khóa Registry để gây lỗi hệ thống hoặc loại bỏ các chứng cứ về sự hiện diện của nó. Cuckoo sẽ theo dõi mọi khóa bị mã độc xóa trong Registry.

Việc xóa khóa có thể được thực hiện để phá vỡ các cấu hình quan trọng hoặc để ngăn chặn các ứng dụng hợp pháp chạy đúng cách, từ đó cản trở khả năng phát hiện mã độc hoặc gây thiệt hại cho hệ thống.

Ví dụ, mã độc có thể xóa khóa liên quan đến cấu hình hệ thống để vô hiệu hóa phần mềm bảo mật hoặc ngăn các ứng dụng khác hoạt động bình thường.

- **Ghi nhận các thao tác ghi giá trị lên các khóa Registry (Monitoring Value Changes in Registry Keys)**

Mã độc không chỉ thao tác lên các khóa Registry, mà còn có thể thay đổi giá trị (value) của các khóa này để thực hiện các hành vi độc hại. Cuckoo sẽ theo dõi mọi thay đổi về giá trị của khóa Registry, bao gồm:

- Thay đổi quyền hạn người dùng để mã độc có thể chạy dưới các quyền cao hơn.
- Thay đổi cài đặt bảo mật của hệ thống, ví dụ như vô hiệu hóa tường lửa hoặc phần mềm diệt virus.
- Cài đặt các đường dẫn để mã độc chạy mỗi khi khởi động hệ thống.

Ví dụ, mã độc có thể thay đổi giá trị trong khóa liên quan đến cấu hình mạng, từ đó chuyển hướng lưu lượng truy cập của hệ thống thông qua máy chủ do hacker kiểm soát.

- **Phát hiện các khóa liên quan đến tự động khởi động (Detecting Auto-Startup Keys)**

Một trong những mục tiêu phổ biến của mã độc là duy trì sự tồn tại trên hệ thống qua việc tự động khởi động mỗi khi hệ thống bật lại. Cuckoo sẽ ghi lại mọi thay đổi trong các khóa khởi động liên quan đến việc chạy mã độc sau khi khởi động lại máy tính.

Các khóa tự khởi động thường bị mã độc thêm vào hoặc chỉnh sửa để thực thi mã độc ngay khi hệ điều hành khởi động. Một số vị trí phổ biến trong Windows Registry mà mã độc thường thao tác để tự động khởi động bao gồm:

- **HKEY_CURRENT_USER\Software\Microsoft\Windows\CurrentVersion\Run**
- **HKEY_LOCAL_MACHINE\Software\Microsoft\Windows\CurrentVersion\Run**

Ví dụ, mã độc ransomware có thể thêm một mục khởi động trong Registry để chạy lại mỗi khi người dùng bật máy tính, từ đó mã hóa dữ liệu của người dùng một cách liên tục.

- **Phân tích hoạt động thay đổi tệp**

Phân tích hoạt động thay đổi hệ thống tệp(File System Changes) trong quá trình phân tích động của Cuckoo Sandbox là một bước quan trọng, giúp theo dõi và ghi nhận mọi thay đổi mà mã độc thực hiện trên hệ thống tệp của máy tính. Mã độc thường thao tác

lên hệ thống tệp để tạo, xóa, hoặc sửa đổi các tệp tin nhằm duy trì sự hiện diện, lây lan, hoặc ẩn mình trong hệ thống, một vài chức năng nổi bật:

- **Giám sát việc tạo tệp tin mới (Monitoring File Creations)**

Mã độc thường tạo ra các tệp tin mới trong quá trình thực thi để lưu trữ các thành phần độc hại, nhật ký, hoặc dữ liệu tạm thời. Cuckoo sẽ ghi lại mọi hành vi tạo tệp mới mà mã độc thực hiện.

Các tệp mới có thể được tạo tại các vị trí khác nhau trên hệ thống, đặc biệt là trong các thư mục có quyền truy cập thấp để tránh bị phát hiện, ví dụ như:

- **%TEMP%:** Thư mục tạm thời, nơi mã độc thường lưu trữ các tệp tin tạm thời hoặc tải về các thành phần khác.
- **%APPDATA%:** Thư mục dữ liệu ứng dụng, nơi mã độc có thể lưu trữ các tệp tin để thực hiện hành vi độc hại.

Ví dụ, một mã độc trojan có thể tạo ra các tệp tin trong thư mục tạm thời để lưu trữ thông tin người dùng bị đánh cắp hoặc tải về các phần mềm độc hại khác từ máy chủ điều khiển.

- **Ghi nhận các tệp bị xóa (Logging File Deletions)**

Sau khi thực hiện các thao tác độc hại, mã độc có thể xóa các tệp tin để xóa dấu vết hoặc ngăn ngừa việc phát hiện. Cuckoo sẽ ghi lại mọi tệp tin bị mã độc xóa trong quá trình thực thi.

Việc xóa tệp thường được thực hiện trên các tệp tin tạm thời hoặc các tệp chứa thông tin độc hại để ngăn cản việc phân tích. Các tệp tin quan trọng của hệ thống cũng có thể bị xóa để gây lỗi hệ thống.

Ví dụ, mã độc ransomware sau khi mã hóa dữ liệu người dùng có thể xóa các bản sao lưu để ngăn việc khôi phục dữ liệu, từ đó ép buộc người dùng trả tiền chuộc.

- **Theo dõi việc sửa đổi tệp tin (Monitoring File Modifications)**

Ngoài việc tạo và xóa tệp, mã độc có thể sửa đổi các tệp tin hiện có để thực hiện hành vi độc hại hoặc để chèn mã độc vào các tệp hợp pháp. Cuckoo sẽ ghi nhận mọi thay đổi nội dung tệp do mã độc gây ra.

Sửa đổi tệp có thể bao gồm việc chèn mã độc vào các tệp hệ thống hoặc tệp thực thi của các chương trình hợp pháp để lây nhiễm mã độc. Mã độc cũng có thể thay đổi cấu trúc của tệp nhật ký để xóa dấu vết hoạt động.

Ví dụ, một mã độc có thể sửa đổi các tệp DLL (Dynamic Link Library) để thực thi mã độc mỗi khi hệ thống chạy một ứng dụng sử dụng tệp DLL đó.

- **Ghi nhận các tệp tải xuống từ mạng (Logging Downloaded Files)**

Nhiều loại mã độc có khả năng tải xuống các tệp tin từ các máy chủ điều khiển từ xa để thực hiện các hành vi độc hại sau khi xâm nhập vào hệ thống. Cuckoo sẽ theo dõi mọi tệp tin được mã độc tải xuống trong quá trình thực thi.

Các tệp tải xuống này thường bao gồm mã độc bổ sung, công cụ tấn công, hoặc các thành phần hỗ trợ cho mã độc. Việc theo dõi tệp tải xuống giúp phát hiện các thành phần bổ sung mà mã độc sử dụng để mở rộng phạm vi tấn công.

Ví dụ, một mã độc downloader có thể tải về các tệp mã độc khác, như ransomware hoặc keylogger, từ máy chủ điều khiển để tấn công hệ thống mục tiêu.

- **Phân tích bộ nhớ**

Phân tích bộ nhớ (Memory Analysis) trong quá trình phân tích động của Cuckoo Sandbox là một bước quan trọng, nhằm trích xuất và phân tích dữ liệu bộ nhớ của các tiến trình malware, cũng như toàn bộ bộ nhớ hệ thống. Việc phân tích bộ nhớ giúp cung cấp thông tin chi tiết về các hoạt động ẩn, thành phần độc hại, và các dữ liệu tạm thời mà mã độc lưu trữ trong bộ nhớ. Điều này hỗ trợ trong việc tái tạo hành vi của mã độc và phát hiện các dữ liệu nhạy cảm mà mã độc có thể truy xuất:

- **Tạo bản sao bộ nhớ tiến trình (Creating Process Memory Dumps)**

Cuckoo Sandbox sẽ tạo bản sao (memory dump) của tất cả các tiến trình mà mã độc khởi tạo hoặc tương tác. Bản dump này bao gồm toàn bộ vùng bộ nhớ mà tiến trình sử dụng, từ đó ta có thể phân tích để hiểu rõ hơn về các thao tác mà tiến trình mã độc thực hiện.

Bộ nhớ của tiến trình thường chứa dữ liệu tạm thời, bao gồm:

- **Tham số API:** Cung cấp thông tin về cách mã độc tương tác với hệ điều hành hoặc các thư viện khác.

- **Thông tin cấu hình:** Các thiết lập mà mã độc sử dụng để điều khiển hoạt động của nó.
- **Dữ liệu nhạy cảm:** Như thông tin về người dùng, mật khẩu, hoặc khóa mã hóa mà mã độc lưu trữ trong bộ nhớ.

Ví dụ, một mã độc trojan có thể lưu trữ thông tin về các máy chủ điều khiển (C&C) hoặc mã thông báo (token) trong bộ nhớ để gửi đi trong quá trình kết nối mạng. Việc phân tích bộ nhớ tiến trình có thể giúp phát hiện các địa chỉ C&C hoặc các hoạt động mạng mà mã độc đang thực hiện.

- **Ghi nhận hành vi thao tác bộ nhớ (Logging Memory Manipulation Activities)**

Mã độc thường thao tác trực tiếp lên bộ nhớ của các tiến trình khác, hoặc tự thao tác bộ nhớ của chính nó, để thực thi mã độc hoặc ẩn giấu hành vi. Cuckoo Sandbox sẽ ghi lại mọi hành vi thao tác bộ nhớ mà mã độc thực hiện.

Các thao tác bộ nhớ phổ biến bao gồm:

- **Chèn mã độc vào bộ nhớ:** Mã độc có thể **tiêm mã** vào bộ nhớ của tiến trình hợp pháp để thực thi mã độc mà không bị phát hiện.
- **Thay đổi dữ liệu trong bộ nhớ:** Mã độc có thể thay đổi các **tham số hệ thống** hoặc **biến số quan trọng** trong bộ nhớ để thay đổi hành vi của tiến trình.

Ví dụ, mã độc có thể sử dụng kỹ thuật DLL injection để chèn một thư viện độc hại vào tiến trình của một ứng dụng hợp pháp, từ đó chiếm quyền điều khiển của tiến trình này.

- **Phân tích cấu trúc mã độc trong bộ nhớ (Analyzing Malware Structure in Memory)**

Bằng cách trích xuất và phân tích nội dung bộ nhớ, ta có thể tái dựng cấu trúc của mã độc mà mã độc đã nạp vào bộ nhớ nhưng không có trên đĩa. Một số mã độc chỉ tồn tại trong bộ nhớ mà không lưu trữ trên hệ thống file để tránh bị phát hiện bởi phần mềm bảo mật.

Phân tích cấu trúc bộ nhớ giúp phát hiện:

- **Mã thực thi của mã độc:** Tìm kiếm và phân tích các đoạn mã độc đã nạp vào bộ nhớ nhưng không tồn tại trên hệ thống tệp.
- **Các thành phần mã hóa:** Mã độc thường sử dụng các kỹ thuật mã hóa hoặc nén dữ liệu để giấu mã của nó. Phân tích bộ nhớ có thể giúp giải mã các thành phần này.

Ví dụ, một mã độc fileless có thể giấu mã trong bộ nhớ và chỉ thực thi trong bộ nhớ mà không để lại bất kỳ tệp nào trên ổ đĩa, khiến cho việc phát hiện trở nên khó khăn hơn.

- **Ghi nhận các dữ liệu nhạy cảm (Logging Sensitive Data in Memory)**

Bộ nhớ thường chứa các dữ liệu nhạy cảm mà mã độc thu thập được, như thông tin đăng nhập, mã thông báo phiên (session tokens), hoặc dữ liệu người dùng. Cuckoo Sandbox sẽ ghi lại các dữ liệu nhạy cảm mà mã độc lưu trữ hoặc xử lý trong bộ nhớ.

Mã độc thường:

- Lưu trữ tạm thời các dữ liệu nhạy cảm trước khi gửi về máy chủ điều khiển.
- Giải mã dữ liệu được mã hóa từ bộ nhớ trước khi sử dụng.

Ví dụ, một mã độc đánh cắp thông tin (infostealer) có thể lưu trữ tạm thời các tên người dùng và mật khẩu mà nó thu thập được từ trình duyệt hoặc ứng dụng khác trong bộ nhớ trước khi gửi đi.

- **Phân tích hoạt động mạng**

Phân tích hoạt động mạng(Advanced Network Analysis) là một trong những bước quan trọng trong quy trình phân tích động của Cuckoo Sandbox nhằm cung cấp cái nhìn sâu hơn về các hoạt động mạng phức tạp mà malware thực hiện. Bước này không chỉ dừng lại ở việc theo dõi và ghi lại lưu lượng mạng thông thường, mà còn mở rộng sang việc phân tích các kỹ thuật mã hóa, phát hiện các kết nối mạng ẩn, và giải mã giao thức để hiểu rõ cách mã độc giao tiếp và truyền dữ liệu:

- **Theo dõi lưu lượng mạng thông thường (Monitoring Regular Network Traffic)**

Cuckoo Sandbox sẽ ghi lại toàn bộ lưu lượng mạng trong quá trình mã độc thực thi, bao gồm các kết nối đến và đi từ máy ảo phân tích. Dữ liệu này sẽ được lưu lại trong định dạng PCAP (Packet Capture) để phân tích chi tiết sau này.

Thông tin ghi lại bao gồm:

- **Địa chỉ IP** của các máy chủ mà mã độc kết nối đến hoặc nhận dữ liệu từ đó.
- **Tên miền** mà mã độc sử dụng để truy vấn hoặc giao tiếp.
- **Giao thức mạng** (HTTP, HTTPS, FTP, DNS, v.v.) và các cổng mạng được sử dụng để truyền tải dữ liệu.

Ví dụ, nếu mã độc liên tục kết nối đến một máy chủ điều khiển và điều khiển (C&C), Cuckoo có thể ghi lại các yêu cầu HTTP hoặc DNS để truy vấn tên miền của máy chủ C&C, hoặc theo dõi địa chỉ IP đích của các kết nối này

- **Giám sát lưu lượng mạng được mã hóa (Monitoring Encrypted Network Traffic)**

Một số mã độc sử dụng mã hóa để giấu các thông tin liên lạc nhằm tránh bị phát hiện bởi các công cụ bảo mật. Để phân tích loại lưu lượng này, Cuckoo sẽ cố gắng:

- **Giải mã lưu lượng** nếu có thể, hoặc
- **Phân tích mô hình lưu lượng** để phát hiện các dấu hiệu bất thường, chẳng hạn như mẫu kết nối mã hóa không hợp lệ hoặc lặp đi lặp lại mà không có lý do rõ ràng.

Ví dụ, nếu mã độc sử dụng HTTPS hoặc một giao thức mã hóa tùy chỉnh để truyền dữ liệu, Cuckoo có thể cố gắng giải mã để xem nội dung thực sự được truyền tải là gì. Nếu không thể giải mã, việc theo dõi kích thước gói tin, tần suất kết nối, và các yếu tố khác có thể giúp xác định liệu mã độc có đang sử dụng mã hóa để giấu hoạt động độc hại hay không.

- **Phát hiện các kết nối mạng ẩn (Detecting Covert Network Connections)**

Một số mã độc sử dụng các kỹ thuật ẩn để che giấu kết nối của chúng, chẳng hạn như:

- **Tunneling** qua các giao thức hợp pháp (như sử dụng DNS hoặc ICMP để gửi dữ liệu thay vì các giao thức truyền tải thông thường).
- **Giao tiếp qua mạng ngang hàng (P2P)** để phân phối dữ liệu mà không cần kết nối trực tiếp đến máy chủ trung tâm.

Cuckoo Sandbox sẽ theo dõi các kết nối ẩn, phát hiện bất kỳ hành vi mạng không bình thường nào, và ghi lại chúng để phân tích sau.

Ví dụ, mã độc có thể sử dụng DNS tunneling để giấu dữ liệu trong các truy vấn DNS hợp pháp. Cuckoo sẽ phát hiện ra các truy vấn DNS bất thường có chứa dữ liệu không mong muốn và ghi lại hành vi này để phân tích kỹ hơn.

- **Phân tích các giao thức mạng (Analyzing Network Protocols)**

Cuckoo Sandbox có khả năng phân tích các giao thức mạng mà mã độc sử dụng để truyền dữ liệu hoặc thao tác hệ thống. Điều này giúp các nhà phân tích hiểu rõ hơn về cơ chế hoạt động của mã độc trong mạng.

Các giao thức được phân tích có thể bao gồm:

- **HTTP/HTTPS:** Để truyền tải các yêu cầu web.
- **FTP:** Để tải lên hoặc tải xuống các tệp từ máy chủ.
- **DNS:** Để phân giải tên miền hoặc thực hiện các cuộc tấn công DNS (như DNS poisoning).
- **SMTP:** Để gửi email lừa đảo hoặc spam.

Ví dụ, một mã độc ransomware có thể sử dụng HTTP để gửi khóa mã hóa về máy chủ của nó sau khi mã hóa dữ liệu của người dùng. Cuckoo có thể phân tích lưu lượng HTTP này để xem chính xác nội dung nào được gửi đi, hoặc phương thức mã hóa nào được sử dụng.

- **Xuất báo Cáo Phân Tích Malware**

Sau khi thực hiện các bước thu thập và phân tích, báo cáo này tổng hợp lại thông tin chi tiết về các hoạt động của malware đã được ghi nhận. Mục tiêu của báo cáo là cung cấp cái nhìn sâu sắc về hành vi của malware, giúp đánh giá mức độ nguy hiểm và khả năng gây hại của nó đối với hệ thống.

- **Thông Tin Tiến Trình Malware:**

- **Tên tiến trình:** [Tên tiến trình của malware]
- **ID tiến trình (PID):** [PID của malware]
- **Đường dẫn:** [Đường dẫn đầy đủ đến tệp thực thi]
- **Thời gian bắt đầu:** [Thời gian tiến trình malware được khởi chạy]

- **Mô tả:** [Mô tả ngắn gọn về tiến trình, nếu có]
- **Hoạt động của tiến trình:**
 - Tạo ra các tiến trình con.
 - Sử dụng tài nguyên hệ thống, bao gồm CPU và bộ nhớ.
 - Liên kết với các tiến trình hợp pháp hoặc tiến trình hệ thống.
- **Hoạt Động Mạng:**
 - **Địa chỉ IP gửi/nhận:** [Địa chỉ IP của các máy tính liên quan]
 - **Cổng sử dụng:** [Cổng TCP/UDP mà malware đã kết nối tới]
 - **Giao thức mạng:** [HTTP, TCP, FTP, v.v.]
 - **Hành vi mạng ghi nhận bao gồm:** thực hiện kết nối tới các máy chủ điều khiển, gửi và nhận dữ liệu mật, thực hiện các cuộc tấn công từ chối dịch vụ (DoS) hoặc tấn công xâm nhập.
- **Thay Đổi Registry:**

Chìa khóa registry bị thay đổi:

 - [Tên chìa khóa]
 - [Giá trị của chìa khóa]

Mục đích: Những thay đổi này có thể bao gồm việc tự động khởi chạy malware khi hệ thống khởi động lại hoặc tạo các mục mới để duy trì sự tồn tại của nó.

- **Thay Đổi Hệ Thống Tập:**

Tập tạo ra hoặc bị thay đổi:

- [Danh sách các tập bị thay đổi hoặc tạo ra bởi malware]

Hành vi: Malware có thể tạo ra các tập tạm thời, ghi đè lên các tập hệ thống quan trọng, hoặc thay đổi các tập cấu hình.

- **Phân Tích Bộ Nhớ:**

Kết quả phân tích bộ nhớ:

- Malware có thể lưu trữ thông tin hoặc mã độc trong bộ nhớ hệ thống.
- Các đoạn mã hoặc chuỗi ký tự đáng ngờ được tìm thấy trong bộ nhớ.

- **Đánh Giá Mức Độ Nguy Hiểm:**
 - **Mức độ nghiêm trọng:** [Nhẹ, Trung bình, Cao]

- **Ảnh hưởng:** [Đánh giá mức độ ảnh hưởng đối với hệ thống, tổ chức hoặc dữ liệu]
- **Khả năng lan truyền:** [Có khả năng lan truyền qua mạng, ổ đĩa ngoài, hoặc phương thức khác]
- **Kết Luận và Đề Xuất:**

Dựa trên các phân tích trên, malware này được đánh giá là [mức độ nguy hiểm]. Để giảm thiểu rủi ro và tác động của malware, chúng tôi khuyến nghị các biện pháp sau:

- Cập nhật phần mềm chống virus và thực hiện quét toàn bộ hệ thống.
- Tạm ngừng hoặc loại bỏ các kết nối mạng không hợp lệ.
- Kiểm tra và khôi phục các tệp hệ thống bị thay đổi.
- Cập nhật các chính sách bảo mật và giám sát hoạt động mạng.

2.4 So sánh phương pháp phân tích tĩnh và phân tích động

Mã độc (malware) đang ngày càng trở thành một vấn đề nghiêm trọng trong thế giới số, với các hình thức tấn công ngày càng tinh vi và khó nhận biết. Để đối phó với các mối đe dọa này, các nhà nghiên cứu và chuyên gia bảo mật thường sử dụng hai phương pháp chính để phân tích mã độc: **phân tích tĩnh** và **phân tích động**. Cả hai phương pháp đều có vai trò quan trọng trong việc hiểu rõ cách thức hoạt động của mã độc và tìm ra giải pháp ngăn chặn. Tuy nhiên, chúng có sự khác biệt về cách thức thực hiện, ưu điểm và hạn chế, tùy thuộc vào mục tiêu và bối cảnh phân tích.

2.4.1 Phân tích Tĩnh

Phân tích tĩnh là quá trình kiểm tra mã độc mà không cần thực thi nó. Phương pháp này tập trung vào việc phân tích cấu trúc và nội dung của mã chương trình, thường là bằng cách xem xét mã nguồn (nếu có) hoặc mã nhị phân của chương trình. Quá trình này bao gồm nhiều kỹ thuật khác nhau như kiểm tra chữ ký, sử dụng trình dịch ngược (disassembler) hoặc trình biên dịch ngược (decompiler) để tìm hiểu về logic và cấu trúc của chương trình mà không cần chạy nó trên hệ thống.

- **Công cụ sử dụng:** Các công cụ phân tích tĩnh phổ biến bao gồm **IDA Pro**, **Ghidra**, **Radare2**, và **OllyDbg**. Ngoài ra, các công cụ nhận dạng file và phân tích định dạng như **PEiD** hay **Exeinfo PE** cũng thường được dùng để xác định loại file và phát hiện các kỹ thuật đóng gói hoặc mã hóa mà mã độc sử dụng.
- **Ưu điểm:**
 - **An toàn:** Phân tích tĩnh không yêu cầu thực thi mã độc, do đó không có nguy cơ gây ra thiệt hại trực tiếp cho hệ thống. Điều này làm cho quá trình phân tích trở nên an toàn hơn, đặc biệt khi xử lý các mẫu mã độc chưa rõ tính chất.

- **Tối ưu hóa thời gian:** Trong nhiều trường hợp, phân tích tĩnh có thể nhanh chóng phát hiện các dấu hiệu của mã độc, đặc biệt nếu sử dụng các công cụ tự động như trình phát hiện chữ ký mã độc.
- **Phát hiện mã độc ẩn:** Phân tích tĩnh có thể tìm ra các thành phần mã độc tiềm ẩn hoặc các đoạn mã chưa được kích hoạt mà phân tích động có thể bỏ qua.
- **Hạn chế:**
 - **Khó phân tích mã bị đóng gói hoặc mã hóa:** Một số mã độc sử dụng kỹ thuật **obfuscation** (làm rối mã) hoặc **packing** (đóng gói) để che giấu ý định thực sự của nó. Trong những trường hợp này, phân tích tĩnh có thể trở nên khó khăn hoặc không thể phát hiện chính xác hành vi của mã độc.
 - **Không thể quan sát hành vi thực tế:** Phân tích tĩnh chỉ cho phép quan sát mã nguồn hoặc mã nhị phân, không cung cấp thông tin về các hành vi mã độc thực sự thực hiện khi được chạy trên hệ thống.

2.4.2 Phân tích Động

Phân tích động là phương pháp thực thi mã độc trong một môi trường được kiểm soát, chẳng hạn như sandbox hoặc máy ảo, để quan sát trực tiếp các hành vi mà mã độc thực hiện khi chạy. Mục tiêu của phương pháp này là tìm hiểu cách mã độc tác động đến hệ thống, bao gồm thay đổi registry, hệ thống file, hoạt động mạng, và các hành động nguy hiểm khác.

- **Công cụ sử dụng:** Các công cụ sandbox như **Cuckoo Sandbox**, **Any.Run**, và **VirusTotal** là những nền tảng phổ biến trong phân tích động. Các công cụ khác như **Process Monitor** và **Wireshark** cũng được sử dụng để theo dõi các tiến trình hệ thống và hoạt động mạng khi mã độc đang chạy.
- **Ưu điểm:**
 - **Quan sát hành vi thực tế:** Phân tích động cho phép các nhà nghiên cứu thấy rõ các hành vi của mã độc khi nó được thực thi. Điều này bao gồm các hoạt động kết nối đến máy chủ từ xa, ghi/đọc dữ liệu từ hệ thống file, và những hành vi nguy hiểm mà mã độc thực hiện.
 - **Phát hiện mã độc vượt qua obfuscation:** Một số mã độc sử dụng các kỹ thuật che giấu mã nguồn chỉ có thể được kích hoạt khi chương trình thực thi. Phân tích động có thể phá vỡ các cơ chế bảo vệ này và cho phép quan sát hành vi mã độc một cách rõ ràng.
 - **Phát hiện kỹ thuật tự ẩn mình:** Nhiều mã độc có khả năng phát hiện môi trường phân tích (anti-analysis) và thay đổi hành vi khi nhận ra rằng nó đang bị giám sát. Phân tích động có thể mô phỏng môi trường thật để đánh lừa mã độc và ghi lại hành vi ẩn của nó.
- **Hạn chế:**

- **Cần môi trường an toàn:** Thực thi mã độc đòi hỏi môi trường an toàn, chẳng hạn như máy ảo hoặc sandbox, để ngăn mã độc lan ra ngoài và gây thiệt hại cho hệ thống thật.
- **Mất thời gian:** Phân tích động có thể yêu cầu thời gian dài để mã độc kích hoạt toàn bộ các hành vi nguy hiểm, đặc biệt khi nó sử dụng các cơ chế trì hoãn hành động hoặc chỉ thực thi khi các điều kiện nhất định được đáp ứng.
- **Khả năng bị mã độc phát hiện:** Một số mã độc có khả năng phát hiện rằng nó đang chạy trong một môi trường phân tích và tự vô hiệu hóa các hành vi nguy hiểm của mình.

2.4.3 So sánh giữa Phân tích Tĩnh và Phân tích Động

Yếu tố	Phân tích Tĩnh	Phân tích Động
Cách thực hiện	Phân tích mã nguồn hoặc mã nhị phân mà không thực thi	Thực thi mã độc trong môi trường ảo để quan sát hành vi
An toàn	An toàn vì không thực thi mã độc	Có rủi ro nếu môi trường không được kiểm soát tốt
Khả năng phát hiện	Hiệu quả với mã không được che giấu, phát hiện chữ ký tĩnh	Phát hiện hành vi động và các hoạt động ẩn của mã độc
Thời gian	Nhanh hơn, nhưng có thể bị giới hạn nếu mã độc được mã hóa	Tốn nhiều thời gian hơn vì cần quan sát toàn bộ chu kỳ hoạt động
Công cụ sử dụng	Trình dịch ngược, trình biên dịch ngược, công cụ phân tích PE	Sandbox, máy ảo, công cụ giám sát hệ thống, công cụ phân tích mạng

2.4.4 Kết luận

Phân tích tĩnh và phân tích động đều là những công cụ quan trọng trong quá trình phân tích mã độc. Phân tích tĩnh phù hợp cho việc tìm hiểu nhanh cấu trúc và các thành phần của mã độc mà không cần thực thi, đồng thời an toàn và nhanh chóng trong nhiều trường hợp. Tuy nhiên, để quan sát hành vi thực sự của mã độc khi được thực thi, phân tích động là phương pháp hiệu quả hơn, đặc biệt trong việc phát hiện các hành vi ẩn. Sự kết hợp cả hai phương pháp này sẽ giúp các nhà nghiên cứu có cái nhìn toàn diện về mã độc, từ đó đưa ra các biện pháp phòng chống hiệu quả hơn.

2.5 Kết chương

Chương này đã giới thiệu khái quát về các lĩnh vực cần chú ý trong phân tích mã độc là mã độc, phương pháp phân tích tĩnh, phương pháp phân tích động, Yarasrules. Giúp đem lại

cái nhìn tổng quan về những lĩnh vực mà nhóm bài tập sẽ nghiên cứu và áp dụng vào bài tập lớn lần này.

CHƯƠNG 3. THỬ NGHIỆM VÀ ĐÁNH GIÁ

3.5 Xây dựng ứng dụng

3.5.1 Khởi tạo và ghi log tệp tin quét

```
self._log_output(f">> Scanning file: {scan_file}\n")
```

Hình 9 Khởi tạo và ghi log tệp tin quét

Dòng mã này ghi lại thông báo vào log, chỉ ra rằng tệp tin nào đang được quét. Việc ghi log giúp theo dõi tiến trình quét tệp tin trong ứng dụng.

Kiểm tra danh sách trắng (Whitelists)

```
white_list_matched = False
for rule in white_list_rules:
    rule_name = os.path.basename(rule)
    yara_command = [self._get_yara_path(), '-s', '-p', '8', '-f', rule, scan_file]
    matched_strings = self._execute_yara(yara_command)

    if matched_strings:
        self._log_output(f" - File is safe (matched white list rule: {rule_name})\n")
        self.matched_strings.append(f"YARA Rule: {rule_name} ({len(matched_strings)} matches)\n{'-'*50}")
        for match in matched_strings:
            self.matched_strings.append(f"{match}")
        self.matched_strings.append('-'*50 + '\n')
        white_list_matched = True
        break
```

Hình 10 Vòng lặp for để kiểm tra danh sách trắng

`white_list_matched = False`: Biến này được khởi tạo với giá trị False để theo dõi xem tệp tin có khớp với bất kỳ quy tắc nào trong danh sách trắng hay không.

`for rule in white_list_rules:` Duyệt qua từng quy tắc trong danh sách trắng `white_list_rules`.

`rule_name = os.path.basename(rule)`: Lấy tên của quy tắc (loại bỏ phần đường dẫn, chỉ lấy tên tệp quy tắc).

`yara_command = [self._get_yara_path(), '-s', '-p', '8', '-f', rule, scan_file]`: Xây dựng câu lệnh YARA để quét tệp tin với quy tắc hiện tại. Câu lệnh này sử dụng các tham số:

-s: In ra kết quả chi tiết.

-p 8: Cấu hình số lượng luồng xử lý (điều này có thể tùy thuộc vào hệ thống hoặc yêu cầu quét).

-f: Thực thi quét với quy tắc YARA được chỉ định.

`matched_strings = self._execute_yara(yara_command)`: Thực thi câu lệnh YARA và nhận kết quả là các chuỗi khớp.

`if matched_strings:` Kiểm tra nếu có kết quả khớp (tức là tệp tin an toàn).

`self._log_output(f" - File is safe (matched white list rule: {rule_name})\n")`: Ghi thông báo vào log cho biết tệp tin an toàn và quy tắc nào đã khớp.

`self.matched_strings.append(f"YARA Rule: {rule_name} ({len(matched_strings)} matches)\n{' '*50}")`: Lưu kết quả vào danh sách `matched_strings` để báo cáo sau.

`for match in matched_strings`: Lặp qua tất cả các chuỗi khớp và thêm chúng vào `matched_strings`.

`white_list_matched = True`: Đánh dấu rằng tệp tin đã khớp với ít nhất một quy tắc trong danh sách trắng.

Kiểm tra xem có khớp danh sách trắng (white list) không

```
if white_list_matched:
    return 'safe'

self._log_output(f" - No matches found in white list.\n")
```

Hình 11 Kiểm tra có khớp danh sách trắng không

Nếu tệp tin đã khớp với một quy tắc trong danh sách trắng (`white_list_matched` là `True`), hàm trả về `'safe'`, chỉ ra rằng tệp tin an toàn.

Nếu không có sự khớp nào trong danh sách trắng, ghi lại thông báo rằng không có kết quả khớp trong danh sách trắng.

Kiểm tra danh sách đen (Blacklists)

```
black_list_matched = False
for rule in black_list_rules:
    rule_name = os.path.basename(rule)
    yara_command = [self._get_yara_path(), '-s', '-p', '8', '-f', rule, scan_file]
    matched_strings = self._execute_yara(yara_command)

    if matched_strings:
        self._log_output(f" - Malware detected (matched black list rule: {rule_name})\n")
        self.matched_strings.append(f"YARA Rule: {rule_name} ({len(matched_strings)} matches)\n{' '*50}")
        for match in matched_strings:
            self.matched_strings.append(f"{match}")
        self.matched_strings.append(' '*50 + '\n')
        black_list_matched = True
        break
```

Hình 12 Vòng lặp for kiểm tra danh sách đen

`black_list_matched = False`: Biến này theo dõi xem tệp tin có khớp với quy tắc nào trong danh sách đen không.

`for rule in black_list_rules`: Duyệt qua từng quy tắc trong danh sách đen `black_list_rules`.

`rule_name = os.path.basename(rule)`: Lấy tên của quy tắc (tên tệp quy tắc).

`yara_command = [self._get_yara_path(), '-s', '-p', '8', '-f', rule, scan_file]`: Tạo câu lệnh YARA để quét tệp tin với quy tắc đen hiện tại.

`matched_strings = self._execute_yara(yara_command)`: Thực thi câu lệnh YARA và nhận kết quả là các chuỗi khớp.

`if matched_strings`: Nếu có chuỗi khớp, có nghĩa là tệp tin có vấn đề và bị đánh dấu là nghi ngờ.

`self._log_output(f' - File is suspicious (matched black list rule: {rule_name})\n')`: Ghi vào log cho biết tệp tin có vấn đề và quy tắc danh sách đen đã khớp.

`self.matched_strings.append(f'YARA Rule: {rule_name} ({len(matched_strings)} matches)\n{' '*50}')`: Lưu kết quả vào danh sách `matched_strings`.

`for match in matched_strings`: Lặp qua các chuỗi khớp và lưu vào `matched_strings`.

`black_list_matched = True`: Đánh dấu rằng tệp tin đã khớp với quy tắc trong danh sách đen.

Kết luận: Trả về kết quả

```
if not black_list_matched:
    self._log_output(f"    - No matches found in black list.\n")

if black_list_matched:
    return 'malware'
else:
    return 'unknown'
```

Hình 13 Trả về kết quả

Nếu không có sự khớp nào trong danh sách đen, ghi lại thông báo rằng không có kết quả khớp trong danh sách trắng.

Nếu `black_list_matched` là `True`, hàm sẽ trả về chuỗi `'malware'`.

Nếu không (nghĩa là `black_list_matched` là `False`), nó trả về chuỗi `'unknown'`.

Nếu không khớp với bất kỳ quy tắc nào trong danh sách đen (nghĩa là `black_list_matched` là `False`), hàm sẽ trả về `'unknown'`, chỉ ra rằng trạng thái của tệp tin không thể xác định.

Với cách thức này, hàm giúp quét tệp tin an toàn bằng cách so sánh với danh sách quy tắc trắng và đen, ghi lại các kết quả và trả về trạng thái cuối cùng của tệp tin.

3.5.2 Gửi tệp tin lên Cuckoo Sandbox

Ghi log thông báo gửi tệp tin

```
self._log_output(f"Sending file to Cuckoo for analysis: {file_path}\n")
```

Hình 14 Ghi log và gửi thông báo

Ghi lại thông báo vào log rằng tệp tin nào đang được gửi đến Cuckoo (một hệ thống phân tích động malware) để phân tích.

Thiết lập thông tin API và header

```
cuckoo_api_url = "http://192.168.10.100:1337/tasks/create/file"
api_token = "5r6pK0JFptvSGTM40Vzhkg"

headers = {
    "Authorization": f"Bearer {api_token}"
}
```

Hình 15 Thiết lập API và header

cuckoo_api_url: Địa chỉ API của Cuckoo mà tệp tin sẽ được gửi tới.

api_token: Mã token để xác thực yêu cầu API, bảo mật quá trình gửi tệp tin.

headers: Cấu hình header cho yêu cầu HTTP, bao gồm Authorization bằng Bearer token.

Mở tệp tin và gửi yêu cầu POST

```
with open(file_path, 'rb') as file_to_upload:
    files = {'file': (os.path.basename(file_path), file_to_upload)}
    response = requests.post(cuckoo_api_url, headers=headers, files=files)
```

Hình 16 Mở tệp tin và gửi yêu cầu POST

with open(file_path, 'rb') as file_to_upload: Mở tệp tin cần gửi ở chế độ nhị phân ('rb').

files: Đóng gói tệp tin vào một dictionary để gửi kèm trong yêu cầu HTTP.

requests.post(...): Gửi tệp tin dưới dạng một yêu cầu POST tới API Cuckoo với đường dẫn, header và tệp tin đã đóng gói.

Kiểm tra kết quả phản hồi từ API

```
if response.status_code == 200:
    self._log_output(f"File {file_path} successfully sent to Cuckoo.\n")
else:
    self._log_output(f"Failed to send file {file_path} to Cuckoo. Status code: {response.status_code}\n")
    self._log_output(f"Response: {response.text}\n")
```

Hình 17 Kiểm tra kết quả phản hồi từ API

Kiểm tra mã trạng thái (status_code): Nếu mã trạng thái là 200, tệp tin đã được gửi thành công. Nếu không, ghi lại lỗi với mã trạng thái và thông báo lỗi từ Cuckoo.

Xử lý lỗi khi gửi yêu cầu

```
except Exception as e:
    self._log_output(f"Error sending file to Cuckoo: {e}\n")
```

Hình 18 Xử lý lỗi khi gửi yêu cầu

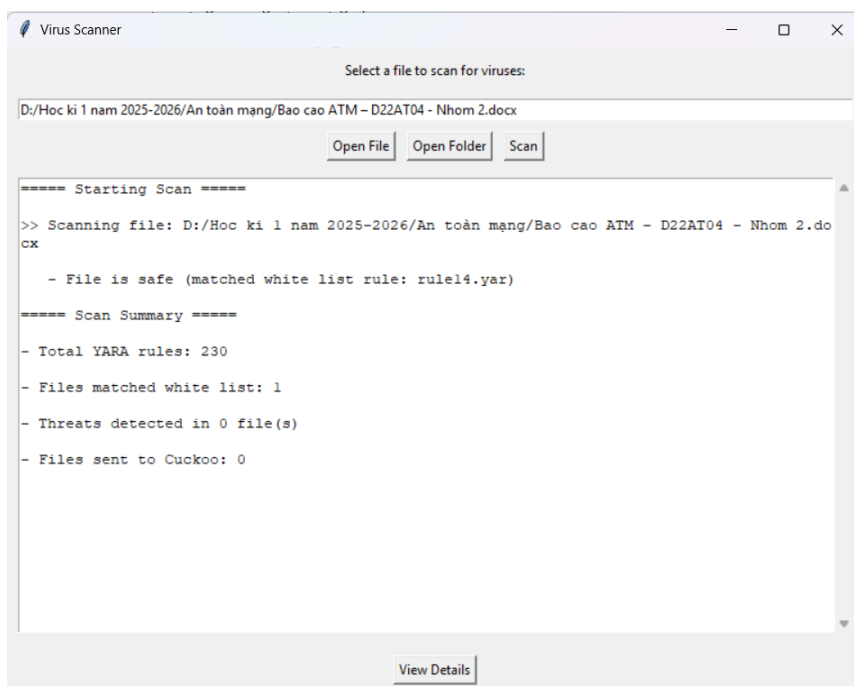
Nếu có bất kỳ lỗi nào trong quá trình gửi tệp tin, một ngoại lệ (exception) sẽ được ném ra. Phần mã này sẽ bắt lỗi và ghi lại thông báo lỗi vào log.

3.6 Triển khai và thử nghiệm

Nhóm sử dụng các yara rule làm cơ sở dữ liệu cho ứng dụng đã viết để tiến hành quét và phân loại tệp.

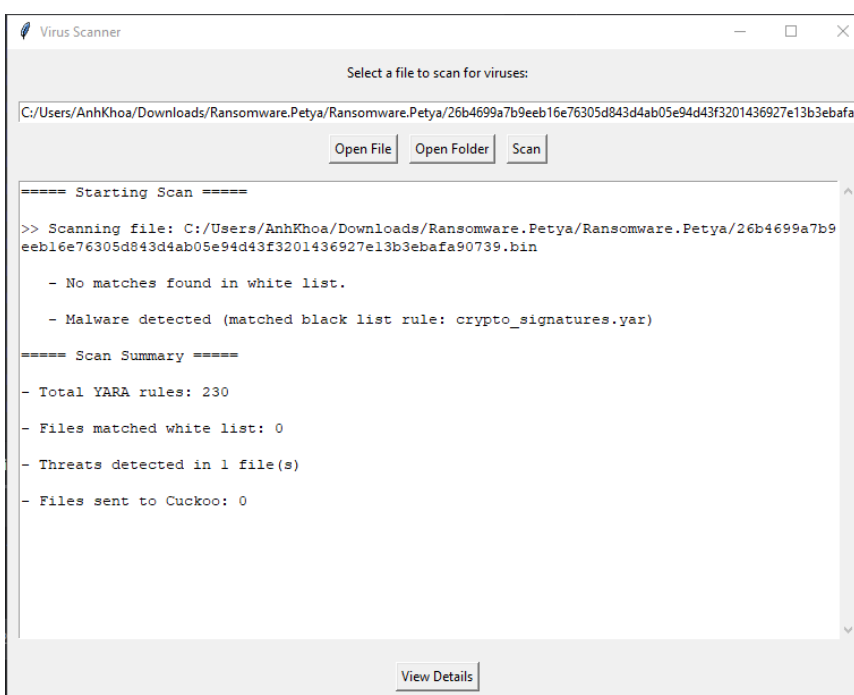
Cơ sở dữ liệu gồm 2 thư mục là white list và black list chứa các yara rule tương ứng giúp phân loại tệp an toàn và tệp có chứa mã độc.

Quét file an toàn:

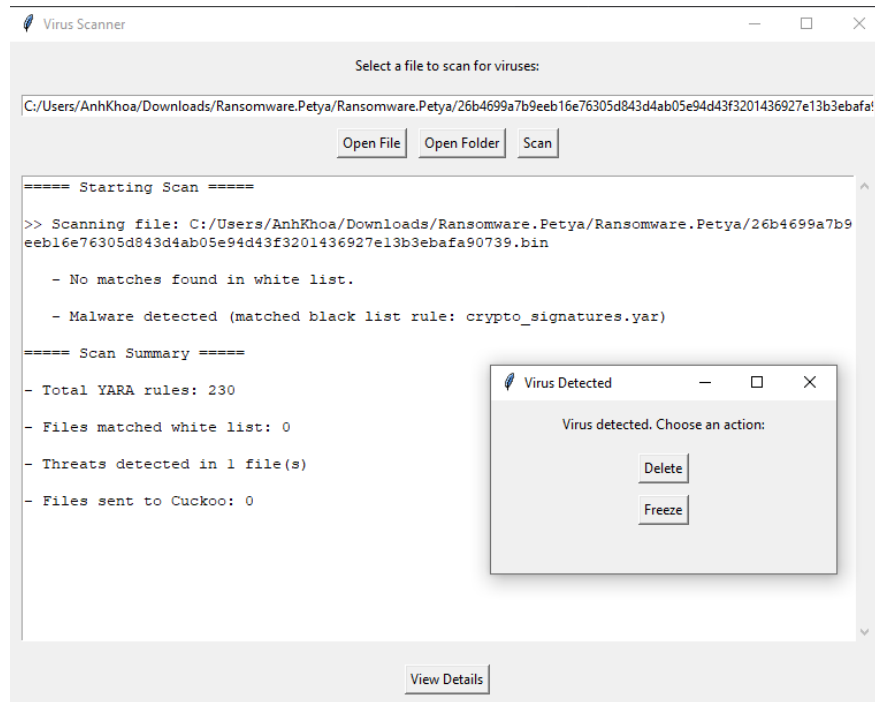


Hình 19 Quét file Excel.exe

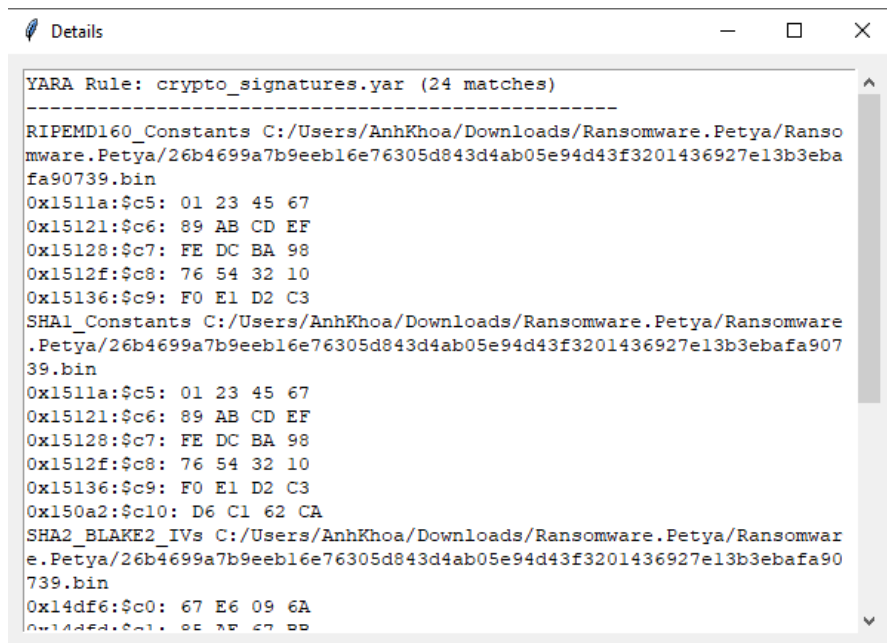
Quét file mã độc:



Hình 20 Quét file mã độc Ransomware.Petya

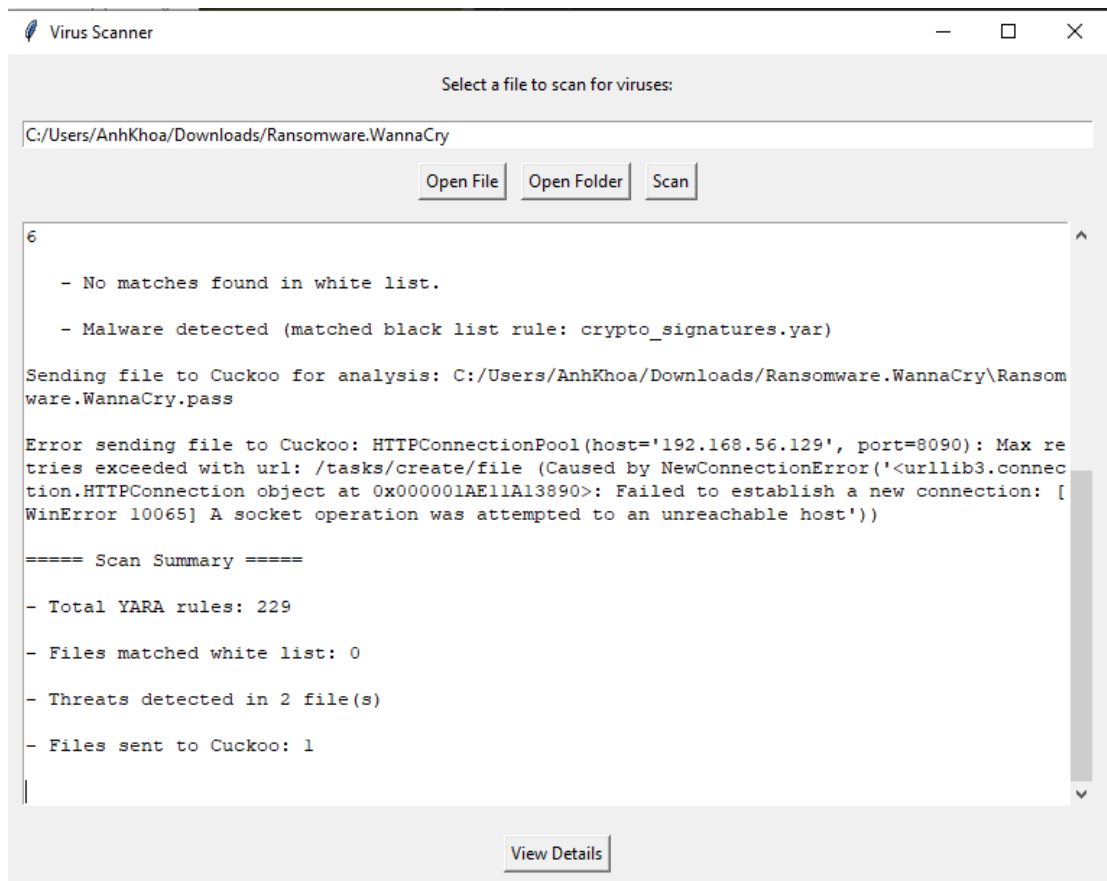


Hình 21 Hiện thị hành động sau khi phát hiện file mã độc



Hình 22 Chi tiết các chuỗi trùng với yara rule

Quét file không có trong cơ sở dữ liệu:



Hình 23 Quét tệp unknow.exe

Khi quét các file không trùng với các rule thuộc white list và black list thì ứng dụng sẽ tự động gửi các file đó tới cuckoo sandbox ở máy chủ để tiến hành phân tích:

```

b22dcat164@ubuntu:~$ workon cuckoo-test
(cuckoo-test) b22dcat164@ubuntu:~$ cuckoo api -H 192.168.56.129 -p 2042
/home/b22dcat164/.virtualenvs/cuckoo-test/local/lib/python2.7/site-packages/sflock/decode/office.py:12: CryptographyDeprecationWarning: Python 2 is no longer supported by the Python core team. Support for it is now deprecated in cryptography, and will be removed in the next release.
  from cryptography.hazmat.backends import default_backend
2025-10-30 22:02:29,768 [werkzeug] INFO: * Running on http://192.168.56.129:2042/ (Press CTRL+C to quit)
2025-10-30 22:03:58,311 [werkzeug] INFO: 192.168.56.128 - - [30/Oct/2025 22:03:58] "POST /tasks/create/file HTTP/1.1" 200 -
  
```

Hình 24 Gửi file lên cuckoo sandbox qua api thành công

Summary

File unknow.exe

Summary	
Size	3.4MB
Type	PE32 executable (GUI) Intel 80386, for MS Windows
MD5	84c82835a5d21bbc775a61706d8ab549
SHA1	5ff465afaabcbf8150d1a3ab2c2e74f3a4426467
SHA256	ed01ebfbc9eb5bba545af4d01bf5f1071661840480439c6e5babe8e080e41aa
SHA512	Show SHA512
CRC32	4822FCAA
ssdeep	None
Yara	None matched

[Download](#)
[Resubmit sample](#)

Score

This file is **very suspicious**, with a score of 16.0 out of 10!

Please notice: The scoring system is currently still in development and should be considered an alpha feature.

Feedback

Expecting different results? Send us this analysis and we will inspect it. [Click here](#)

Hình 25 Kết quả phân tích từ Cuckoo Sandbox đối với tệp tin

Cuckoo Sandbox đánh giá tệp tin này là rất đáng ngờ, với điểm số 16.0 (cao hơn nhiều so với giới hạn cảnh báo là 10).

Đây là một dấu hiệu rõ ràng cho thấy tệp này có thể là phần mềm độc hại.

Tiếp theo, nhóm sẽ sử dụng kết quả mã cuckoo trả về để tiến hành phân tích và viết yara rule bổ sung thêm vào cơ sở dữ liệu.

```
Name: infostealer_keylogger
  Description: Creates a windows hook that monitors keyboard input (keylogger)
  Severity: 3
  Mark Count: 1
Name: modifies_boot_config
  Description: Modifies boot configuration settings
  Severity: 3
  Mark Count: 1
Name: ransomware_extensions
  Description: Appends a known WannaCry ransomware file extension to files that have been encrypted
  Severity: 3
  Mark Count: 1496
Name: ransomware_mass_file_delete
  Description: Deletes a large number of files from the system indicative of ransomware, wiper malware or system destruction
  Severity: 3
  Mark Count: 1905
Name: ransomware_message
  Description: Writes a potential ransom message to disk
  Severity: 3
  Mark Count: 1
Name: ransomware_shadowcopy
  Description: Removes the Shadow Copy to avoid recovery of the system
  Severity: 3
  Mark Count: 2
Name: injection_resumethread
  Description: Resumed a suspended thread in a remote process potentially indicative of process injection
  Severity: 3
  Mark Count: 2
Name: suspicious_command_tools
  Description: Uses suspicious command line tools or Windows utilities
  Severity: 3
  Mark Count: 3
Name: ransomware_dropped_files
  Description: Drops 399 unknown file mime types indicative of ransomware writing encrypted files back to disk
  Severity: 4
  Mark Count: 399
Name: ransomware_file_moves
  Description: Performs 1678 file moves indicative of a ransomware file encryption process
  Severity: 6
  Mark Count: 1678
Name: ransomware_appends_extensions
  Description: Appends a new file extension or content to 1678 files indicative of a ransomware file encryption process
  Severity: 6
  Mark Count: 1678
```

Hình 26 Các signature có mức độ nghiêm trọng cao của mã độc trích xuất trong file report.json

Qua các signature trên có thể kết luận được mã độc thuộc nhóm **ransomware**, cụ thể là các biến thể tương tự **WannaCry**.

Nhóm tiếp tục phân tích sâu hơn để khám phá các đặc trưng, hành vi của mã độc trên máy nạn nhân:

3.6.1 Phân tích tĩnh cơ bản

Phân tích chuỗi

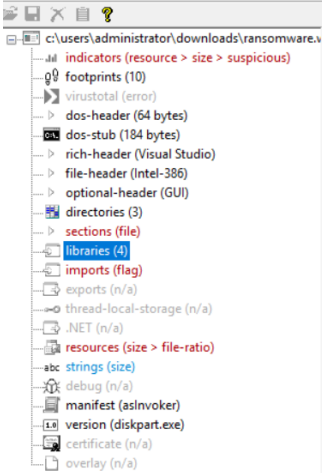
```
115p7UMMngoJ1pMvKpHiJcRdfJNXj6LrLn
12t9YDPgwueZ9NyMgw519p7AA8isjr6SMw
13AM4VW2dhxYgXeQepoHkHSQuy6NgaEb94|
```

Hình 27 Danh sách địa chỉ bitcoin

```
inflate 1.1.3 Copyright 1995-1998 Mark Adler
Qkkbal
- unzip 0.15 Copyright 1998 Gilles Vollant
```

Hình 28 Các công cụ mã độc sử dụng

Phân tích thư viện và hàm



library (4)	duplicate (0)	flag (0)	bound (0)	first-thunk-original (INT)	first-thunk (IAT)	type (1)	imports (114)
KERNEL32.dll	-	-	-	0x00000638	0x0000802C	implicit	54
USER32.dll	-	-	-	0x000007DC	0x000081D0	implicit	1
ADVAPI32.dll	-	-	-	0x0000060C	0x00008000	implicit	10
MSVCRT.dll	-	-	-	0x00000714	0x00008108	implicit	49

Hình 29 Các thư viện của mã độc

- KERNEL32.dll:
 - KERNEL32.dll là một thư viện động quan trọng trong hệ điều hành Windows, cung cấp nhiều hàm cơ bản mà các ứng dụng Windows sử dụng để thực hiện các thao tác ở mức hệ thống. Tập DLL này chứa các hàm quản lý bộ nhớ, xử lý tệp, điều khiển quá trình thực thi, và các thao tác khác liên quan đến quản lý tài nguyên hệ thống.
 - Kẻ tấn công có thể lợi dụng để tạo hoặc dừng các tiến trình, luồng thực thi của các ứng dụng anti virus (CreateProcess, CreateThread, ExitProcess, ExitThread). Ngoài ra còn có thể tạo, thêm, sửa xóa dữ liệu của các file như (CreateFile, ReadFile, WriteFile, DeleteFile).
- USER32.dll:

- USER32.dll là một thư viện động trong hệ điều hành Windows, đóng vai trò quan trọng trong việc quản lý giao diện người dùng (User Interface) và tương tác với các thành phần giao diện đồ họa trên hệ thống. USER32.dll cung cấp các hàm giúp ứng dụng xử lý cửa sổ, nhận thông tin từ bàn phím và chuột, quản lý các hộp thoại và menu, và thực hiện các chức năng cơ bản liên quan đến giao diện người dùng.
- Kẻ tấn công có thể lợi dụng để thu thập các thông tin nhạy cảm của nạn nhân như tài khoản, mật khẩu khi thực hiện thao tác nhập trên bàn phím hay chuột thông qua các hàm như GetKeyState, GetAsyncKeyState. Ngoài ra kẻ tấn công có thể lợi dụng các hàm quản lý hộp thoại như CreateDialog để đánh lừa người dùng đang bị nhiễm virus cần thực hiện theo các yêu cầu của kẻ tấn công để gỡ bỏ, ...
- ADVAPI32.dll:
 - ADVAPI32.dll là một thư viện động trong Windows, cung cấp các hàm liên quan đến quản lý bảo mật, tài khoản người dùng, dịch vụ hệ thống, và một số tác vụ hệ thống khác. Thư viện này được viết tắt từ "Advanced API", có nghĩa là một tập hợp các API nâng cao. ADVAPI32.dll đóng vai trò quan trọng trong việc quản lý các tính năng bảo mật và quyền hạn của hệ thống, giúp các ứng dụng có thể truy cập và kiểm soát các dịch vụ và tài nguyên hệ thống một cách an toàn.
 - Kẻ tấn công có thể lợi dụng thư viện này để tạo các dịch vụ độc hại chạy ngầm bằng hàm CreateService hay thực hiện mã hóa dữ liệu người dùng thông qua các hàm CryptEncrypt, CryptDecrypt, và CryptGenKey.
- MSVCRT.dll:
 - MSVCRT.dll là một thư viện động trong Windows cung cấp các hàm thư viện thời gian chạy (runtime library) của Microsoft C (Microsoft Visual C++ Runtime Library). Thư viện này bao gồm các hàm cơ bản cho các thao tác xử lý chuỗi, toán học, quản lý bộ nhớ, thao tác I/O, và các chức năng cấp thấp khác mà nhiều ứng dụng Windows và chương trình C/C++ phụ thuộc vào để thực thi.

Nhóm sử dụng pestudio để xác định các hàm có hành vi đáng ngờ hoặc có khả năng độc hại:

imports (114)	flag (14)	callback (0)	first-thunk-original (INT)	first-thunk (IAT)	hint	group (10)	technique (11)
CreateServiceA	*	-	0x0000C2A	0x0000C2A	100 (0x0064)	services	T1543 Create or
RegCreateKeyW	*	-	0x0000C04	0x0000C04	467 (0x01D3)	registry	T1112 Modify P
RegSetValueExA	*	-	0x0000BF2	0x0000BF2	516 (0x0204)	registry	T1112 Modify P
VirtualProtect	*	-	0x0000B36	0x0000B36	902 (0x0386)	memory	T1055 Process I
WriteFile	*	-	0x000097E	0x0000D97E	932 (0x03A4)	file	-
SetFileAttributesW	*	-	0x000098A	0x0000D98A	794 (0x031A)	file	-
CreateProcessA	*	-	0x0000B32	0x0000D932	102 (0x0066)	execution	T1106 Execution
TerminateProcess	*	-	0x0000B08	0x0000D908	862 (0x035E)	execution	-
GetExitCodeProcess	*	-	0x00007F2	0x0000D7F2	346 (0x015A)	execution	-
CryptReleaseContext	*	-	0x0000C14	0x0000DCE14	160 (0x00A0)	cryptography	T1027 Obfuscate
rand	*	-	0x0000CE6	0x0000DCE6	678 (0x02A6)	cryptography	T1027 Obfuscate
srand	*	-	0x0000CEE	0x0000DCEE	692 (0x02B4)	cryptography	T1027 Obfuscate
SetCurrentDirectoryW	*	-	0x00009D0	0x0000D9D0	779 (0x030B)	-	-
SetCurrentDirectoryA	*	-	0x0000882	0x0000D882	778 (0x030A)	-	-
InitializeCriticalSection	-	-	0x0000930	0x0000D930	547 (0x0223)	synchronization	-
DeleteCriticalSection	-	-	0x000094C	0x0000D94C	129 (0x0081)	synchronization	-
LeaveCriticalSection	-	-	0x000098A	0x0000D98A	593 (0x0251)	synchronization	-
EnterCriticalSection	-	-	0x00009A2	0x0000D9A2	152 (0x0098)	synchronization	-
OpenMutexA	-	-	0x0000A84	0x0000DA84	644 (0x0284)	synchronization	-
WaitForSingleObject	-	-	0x0000B1C	0x0000DB1C	912 (0x0390)	synchronization	-
OpenServiceA	-	-	0x0000C62	0x0000DC62	431 (0x01AF)	services	T1543 Create or
StartServiceA	-	-	0x0000C52	0x0000DC52	585 (0x0249)	services	T1569 System S
CloseServiceHandle	-	-	0x0000C3C	0x0000DC3C	62 (0x003E)	services	T1569 System S
OpenSCManagerA	-	-	0x0000C72	0x0000DC72	429 (0x01AD)	services	T1569 System S
SizeofResource	-	-	0x0000A3A	0x0000DA3A	853 (0x0355)	resource	-
LockResource	-	-	0x0000A4C	0x0000DA4C	613 (0x0265)	resource	-
LoadResource	-	-	0x0000A3C	0x0000DA3C	599 (0x0257)	resource	-
FindResourceA	-	-	0x0000A6C	0x0000DA6C	227 (0x00E3)	resource	-

Hình 30 Imports trong Pestudio

- CreateServiceA (ADAPI32.dll):
 - Hàm CreateServiceA tạo hoặc cài đặt một dịch vụ mới vào Service Control Manager (SCM) của Windows. Dịch vụ này có thể được thiết lập để tự động khởi động cùng hệ thống hoặc khởi chạy khi có yêu cầu. Thường dùng để khởi tạo các dịch vụ chạy ngầm trong hệ thống, thường cần quyền quản trị cao.
 - Ứng dụng độc hại: Một số mã độc có thể sử dụng hàm này để tự cài đặt dưới dạng dịch vụ, giúp chúng chạy tự động mỗi khi hệ thống khởi động lại.
- RegSetValueExA (ADAPI32.dll):
 - Hàm RegSetValueExA ghi dữ liệu vào một khóa đăng ký (Registry key) cụ thể trong Windows. Dùng để thay đổi các cài đặt hệ thống hoặc ứng dụng, lưu trữ cấu hình, và có thể ghi dữ liệu như chuỗi ký tự hoặc số nguyên vào Registry.
 - Ứng dụng độc hại: Mã độc có thể sử dụng hàm này để thay đổi các cài đặt hệ thống nhằm duy trì sự tồn tại hoặc thay đổi hành vi của các phần mềm khác.
- VirtualAlloc (KERNEL32.dll):
 - Hàm VirtualAlloc cấp phát bộ nhớ động trong không gian địa chỉ ảo của quá trình đang chạy. Được sử dụng trong việc cấp phát bộ nhớ cho các thao tác như nạp mã mới vào bộ nhớ.

- Ứng dụng độc hại: Mã độc thường dùng VirtualAlloc để phân bổ bộ nhớ cho mã độc hoặc mã thực thi tại thời điểm chạy.
- VirtualProtect (KERNEL32.dll):
 - Hàm VirtualProtect thay đổi quyền truy cập bộ nhớ (chẳng hạn từ chỉ đọc sang đọc/ghi hoặc thực thi). Dùng để điều chỉnh quyền truy cập cho các phân vùng bộ nhớ đã cấp phát.
 - Ứng dụng độc hại: Mã độc có thể sử dụng để thực hiện các thao tác khó phát hiện như biến bộ nhớ chỉ đọc thành có thể thực thi, từ đó nạp và thực thi mã độc.
- WriteFile (KERNEL32.dll):
 - WriteFile ghi dữ liệu vào một tệp đã mở hoặc một thiết bị I/O. Thường dùng để lưu dữ liệu vào tệp.
 - Ứng dụng độc hại: Mã độc có thể dùng hàm này để ghi dữ liệu vào các tệp hệ thống hoặc ghi dữ liệu thu thập được từ người dùng.
- CreateProcessA (KERNEL32.dll):
 - CreateProcessA khởi chạy một tiến trình mới, có thể là một ứng dụng hoặc dịch vụ. Dùng để chạy một ứng dụng khác từ trong một chương trình.
 - Ứng dụng độc hại: Mã độc thường dùng hàm này để tạo ra các tiến trình phụ trợ hoặc để chạy các tệp độc hại khác.
- TerminateProcess (KERNEL32.dll):
 - Hàm TerminateProcess kết thúc một quy trình đang chạy. Thường được sử dụng để đóng các ứng dụng không còn đáp ứng hoặc cần phải bị dừng.
 - Ứng dụng độc hại: Một số mã độc dùng hàm này để kết thúc các quy trình bảo mật hoặc chống mã độc, nhằm vô hiệu hóa hệ thống bảo vệ của máy tính.
- CryptReleaseContext (ADAPI32.dll):

- CryptReleaseContext giải phóng ngữ cảnh mã hóa được tạo bởi CryptAcquireContext. Dùng để kết thúc và giải phóng tài nguyên mã hóa sau khi đã thực hiện xong.
- Ứng dụng độc hại: Mã độc có thể sử dụng trong các hoạt động mã hóa và giải mã nhằm giấu các dữ liệu nhạy cảm hoặc giao tiếp bảo mật.
- Rand (MSVRT.dll):
 - Rand tạo ra một số ngẫu nhiên trong phạm vi xác định. Dùng trong các trường hợp cần tạo số ngẫu nhiên, như tạo mã bảo mật, tạo độ trễ ngẫu nhiên.
 - Ứng dụng độc hại: Một số mã độc sử dụng số ngẫu nhiên để làm khó phân tích bằng cách tạo các biến đổi ngẫu nhiên trong hành vi của mã.
- Srand (MSVRT.dll):
 - Srand khởi tạo chuỗi số ngẫu nhiên dựa trên một hạt giống (seed). Được gọi trước khi sử dụng Rand để đảm bảo chuỗi số ngẫu nhiên được thay đổi dựa trên seed.
 - Ứng dụng độc hại: Mã độc có thể dùng Srand để đảm bảo số ngẫu nhiên được tạo ra khác nhau giữa các lần chạy, khiến các hành vi khó dự đoán hơn.
- SetCurrentDirectoryA (KERNEL32.dll):
 - SetCurrentDirectoryA thay đổi thư mục làm việc hiện tại cho quy trình đang chạy. Dùng để thay đổi thư mục làm việc khi cần truy cập vào một thư mục khác.
 - Ứng dụng độc hại: Mã độc có thể thay đổi thư mục hiện tại sang một thư mục mà nó lưu trữ các tệp độc hại, từ đó có thể dễ dàng thao tác các tệp mà không cần chỉ định đường dẫn tuyệt đối.

3.2.2 Phân tích động

Phân tích hoạt động mạng (Network Activity)

Network Activity:

DNS Requests:

- Domain: `www.msftncsi.com`, IP: N/A
- Domain: `time.windows.com`, IP: N/A
- Domain: `dns.msftncsi.com`, IP: N/A
- Domain: `teredo.ipv6.microsoft.com`, IP: N/A

HTTP Requests:

- URL: `http://www.msftncsi.com/ncsi.txt`, Method: GET

IP Connections:

- IP: `113.171.230.17`
- IP: `8.8.4.4`
- IP: `8.8.8.8`

Hình 31 Danh sách các hoạt động mạng

1. Các hoạt động hợp pháp nhưng cần điều tra thêm:

- Các tên miền của Microsoft (`www.msftncsi.com`, `time.windows.com`, ...) thường hợp pháp trong môi trường Windows, nhưng nếu mã độc thực hiện chúng, có khả năng nó đang kiểm tra kết nối mạng hoặc phát hiện môi trường sandbox.

2. IP không rõ nguồn gốc (113.171.230.17):

- Đây có thể là địa chỉ máy chủ C2. Cần kiểm tra kỹ nguồn gốc IP này qua các công cụ OSINT.

3. Tính chất khả nghi:

- Nếu tất cả các hành động trên xuất phát từ một mã độc, nó có thể:
 - Kiểm tra kết nối mạng trước khi thực hiện các hành động độc hại.
 - Phát hiện môi trường sandbox để quyết định có nên thực thi mã độc hay không.
 - Giao tiếp với máy chủ điều khiển (C2) để nhận lệnh hoặc tải xuống payload bổ sung.

Phân tích hành vi (Behavioral Analysis)

command_line:

```
- wmic shadowcopy delete
- 291481734139436.bat
- taskdl.exe
- @WanaDecryptor@.exe vs
- icacls . /grant Everyone:F /T /C /Q
- cmd.exe /c vssadmin delete shadows /all /quiet & wmic shadowcopy delete & bcdedit /set {default} bootstatuspolicy ignoreallfailures & bcdedit /set {default} recoverynabled no & wbadmin delete catalog -quiet
- attrib +h .
- cscript.exe //nologo m.vbs
- TaskData\Tor\taskhsvc.exe
- vssadmin delete shadows /all /quiet
- taskse.exe C:\Users\Administrator\AppData\Local\Temp\@WanaDecryptor@.exe
- @WanaDecryptor@.exe co
- cmd.exe /c start /b @WanaDecryptor@.exe vs
- @WanaDecryptor@.exe
```

Hình 32 Danh sách các câu lệnh sử dụng

Danh sách các lệnh này chứa nhiều hành động nghi ngờ liên quan đến ransomware hoặc phần mềm độc hại, với các chức năng khác nhau, như phá hủy bản sao lưu, thay đổi quyền truy cập tệp, và thực thi mã độc.

1. wmic shadowcopy delete

- Mục đích:
 - Lệnh này sử dụng công cụ **Windows Management Instrumentation Command-line (WMIC)** để xóa các bản sao lưu shadow copy trên hệ thống.
 - **Shadow copy** thường được sử dụng để phục hồi dữ liệu hoặc hệ thống. Việc xóa nó là hành vi phổ biến của ransomware để ngăn chặn người dùng khôi phục dữ liệu sau khi bị mã hóa.

2. 291481734139436.bat

- Mục đích:
 - Đây là một tệp batch script (.bat), thường chứa các lệnh để tự động hóa hoặc triển khai hoạt động độc hại.
 - Tên tệp có thể được tạo ngẫu nhiên để tránh bị phát hiện bởi các công cụ bảo mật.
 - **Hành động đề xuất:** Kiểm tra nội dung của tệp batch để xác định các lệnh mà nó thực hiện.

3. taskdl.exe

- Mục đích:
 - Đây có thể là một tệp thực thi độc hại, được sử dụng để thực hiện các hành động cụ thể, chẳng hạn như tải xuống hoặc thực thi các tệp bổ sung.
 - **Hành động đề xuất:** Kiểm tra tệp qua các công cụ như VirusTotal hoặc phân tích hành vi trong môi trường sandbox.

4. @WanaDecryptor@.exe vs

- Mục đích:
 - Đây là một tệp thực thi có tên tương tự WannaCry ransomware.
 - Hành vi của WannaCry bao gồm mã hóa tệp, hiển thị tin nhắn đòi tiền chuộc, và lan truyền qua SMB.
 - Từ "vs" có thể là một tham số chỉ định chế độ hoặc hành động mà tệp thực hiện.
 - **Hành động đề xuất:** Kiểm tra tệp thực thi này cẩn thận vì nó có khả năng cao là mã độc.

5. icacls . /grant Everyone:F /T /C /Q

- Mục đích:
 - Sử dụng công cụ **icacls** để cấp quyền truy cập "**Full Control (F)**" cho tất cả người dùng (Everyone) trên thư mục hiện tại (dấu .).
 - Tùy chọn:
 - **/T:** Áp dụng cho tất cả các tệp và thư mục con.
 - **/C:** Tiếp tục thực hiện ngay cả khi gặp lỗi.
 - **/Q:** Ẩn đầu ra.
 - Hành vi này cho phép mã độc tự do đọc, ghi, hoặc sửa đổi bất kỳ tệp nào trên hệ thống.

6. cmd.exe /c vssadmin delete shadows /all /quiet ...

- Mục đích:

- Đây là một chuỗi lệnh liên quan đến việc xóa bản sao lưu và vô hiệu hóa các tính năng khôi phục hệ thống:
 - **vssadmin delete shadows /all /quiet**: Xóa tất cả shadow copy trên hệ thống một cách âm thầm.
 - **wmic shadowcopy delete**: Thực hiện lại việc xóa shadow copy bằng WMIC.
 - **bcdedit /set {default} bootstatuspolicy ignoreallfailures**: Vô hiệu hóa chính sách lỗi khởi động.
 - **bcdedit /set {default} recoveryenabled no**: Vô hiệu hóa chế độ phục hồi.
 - **wbadmin delete catalog -quiet**: Xóa catalog của bản sao lưu hệ thống.
- Hành vi này là đặc trưng của ransomware, nhằm ngăn chặn nạn nhân khôi phục dữ liệu hoặc hệ thống.

7. attrib +h .

- Mục đích:
 - Sử dụng lệnh **attrib** để ẩn thư mục hoặc tệp hiện tại bằng cách gán thuộc tính **hidden (+h)**.
 - Điều này giúp mã độc hoạt động ẩn mà người dùng không phát hiện ra.

8. cscript.exe //nologo m.vbs

- Mục đích:
 - Chạy tệp script VBScript (m.vbs) bằng công cụ **cscript**.
 - **Tùy chọn**:
 - **//nologo**: Ẩn thông báo phiên bản khi chạy script.
 - Tệp VBScript này có thể thực hiện các hành động độc hại, chẳng hạn như tải xuống payload hoặc điều khiển hệ thống.

9. TaskData\Tor\taskhsvc.exe

- Mục đích:
 - Tập thực thi này có thể liên quan đến Tor, một công cụ để ẩn danh kết nối mạng.
 - Mã độc thường sử dụng Tor để liên lạc với máy chủ điều khiển (C2), che giấu nguồn gốc giao tiếp.

10. vssadmin delete shadows /all /quiet

- Mục đích:
 - Tương tự lệnh trên, xóa tất cả shadow copy trên hệ thống để ngăn chặn khôi phục dữ liệu.

11. taskse.exe C:\Users\Administrator\AppData\Local\Temp\@WanaDecryptor@.exe

- Mục đích:
 - **taskse.exe** có thể là một tập thực thi độc hại, dùng để khởi chạy ransomware @WanaDecryptor@.exe từ thư mục tạm.

12. cmd.exe /c start /b @WanaDecryptor@.exe vs

- Mục đích:
 - Chạy @WanaDecryptor@.exe ở chế độ nền (**start /b**) thông qua Command Prompt.
 - Điều này cho phép ransomware thực thi một cách âm thầm mà không hiển thị giao diện.

Dựa trên phân tích nhóm kết luận được chức năng chính của các lệnh:

- Xóa bản sao lưu (shadow copy), vô hiệu hóa khôi phục hệ thống.
- Thay đổi quyền truy cập để mã độc dễ dàng mã hóa hoặc phá hủy tệp.
- Ẩn tệp hoặc thực thi ransomware một cách âm thầm.
- Giao tiếp qua Tor để nhận lệnh từ máy chủ điều khiển.

```
mutex:  
- Global\CDBurnExclusive  
- MsWinZonesCacheCounterMutexA  
- CDBurnNotify  
- Global\MsWinZonesCacheCounterMutexA0
```

Hình 33 Danh sách các mutex mã độc sử dụng

1. Global\CDBurnExclusive:

- Đây có thể là một mutex được sử dụng trong một phần mềm sao chép đĩa (CD burning software) hoặc một phần mềm liên quan đến ghi đĩa.
- Phần mềm độc hại có thể sử dụng mutex này để kiểm tra xem có bất kỳ ứng dụng nào đang chạy liên quan đến ghi đĩa hay không, hoặc ngừng các tiến trình ghi đĩa để đảm bảo chúng không bị phát hiện.

2. MsWinZonesCacheCounterMutexA:

- Mutex này có thể liên quan đến hệ thống quản lý vùng (zones) trong Windows, chẳng hạn như các vùng bảo mật Internet Explorer sử dụng để phân loại các tệp tin tải xuống hoặc mở.
- Phần mềm độc hại có thể sử dụng mutex này để điều khiển việc truy cập vào các tệp tin từ các vùng khác nhau trong hệ thống, giúp nó tránh được sự phát hiện từ các ứng dụng bảo mật.

3. CDBurnNotify:

- Đây có thể là một mutex khác liên quan đến các phần mềm sao chép đĩa (CD/DVD burning software). Phần mềm độc hại có thể sử dụng mutex này để đảm bảo rằng không có phần mềm sao chép đĩa nào đang chạy hoặc thông báo không bị làm gián đoạn khi thực thi.

4. Global\MsWinZonesCacheCounterMutexA0:

- Đây là một mutex khác liên quan đến MsWinZonesCacheCounterMutexA (nó có thể là một biến thể của mutex này, có thể liên quan đến các tác vụ bảo mật hoặc phân loại các vùng tệp tin trong hệ thống).

- Cũng giống như mutex trước, phần mềm độc hại có thể sử dụng mutex này để truy cập các vùng tệp tin mà không bị các phần mềm bảo mật hoặc các ứng dụng khác ngăn chặn.

```
buffer:Q: What's wrong with my files? A: Oops, your important files are encrypted. It means you will not be able to access them
anymore until they are decrypted. If you follow our instructions, we guarantee that you can decrypt all your files quickly and
safely! Let's start decrypting! Q: What do I do? A: First, you need to pay service fees for the decryption. Please send $300 worth
of bitcoin to this bitcoin address: 13AM4VW2dhxYgXeQepoHkH5Quy6NgaEb94 Next, please find an application file named
"@WanaDecryptor.exe". It is the decrypt software. Run and follow the instructions! (You may need to disable your antivirus for a
while.) Q: How can I trust? A: Don't worry about decryption. We will decrypt your files surely because nobody will trust us if we
cheat users. * If you need our assistance, send a message by clicking <Contact Us> on the decryptor window.
offset:0
file_handle:0x0000011c
filepath:C:\Users\Administrator\AppData\Local\Temp\@Please_Read_Me@.txt
```

Hình 34 Đoạn tin nhắn đáng ngờ

```
"urls": [
    "https://en.wikipedia.org/wiki/Bitcoin",
    "https://www.google.com/search?q=how",
    "http://www.btcfrog.com/qr/bitcoinPNG.php?address=%s"
],
```

Hình 35 Các url liên quan đến bitcoin

Sau khi hoàn thành phân tích mã độc, nhóm phát triển tiến hành viết yara rule để bổ sung thêm vào cơ sở dữ liệu:

```
rule WannaCry_Detect
{
    strings:
        //Chuoi kha nghi
        $string1 = "WNCry@2017" wide ascii
        $string2 = "Wana Decrypt0r 2.0" wide ascii
        $string3 = "Wana Decryptor" wide ascii
        $string4 = "wanacrypt0r" wide ascii
        $string6 = "WANACRY!" wide ascii
        $string7 = ".WNCRYT" wide ascii

        //Loi nhan
        $comment1 = "Q: What's wrong with my files?" wide ascii
        $comment2 = "A: Oops, your important files are encrypted. It means you will not be able to access them anymore until they are decrypted." wide ascii
        $comment3 = "Q: What do I do?" wide ascii
        $comment4 = "A: First, you need to pay service fees for the decryption." wide ascii
        $comment5 = "Q: How can I trust?" wide ascii
        $comment6 = "A: Don't worry about decryption." wide ascii
        $comment7 = "Please select a host to decrypt." wide ascii
        $comment8 = "All your files have been decrypted!" wide ascii
        $comment9 = "Pay now, if you want to decrypt ALL your files!" wide ascii

        //Lenh su dung
        $lenh1 = "cmd.exe /c" wide ascii
        $lenh2 = "icacls . /grant Everyone:F /T /C /Q" wide ascii
        $lenh3 = "attrib +h" wide ascii
        $lenh4 = "vssadmin delete shadows /all /quiet" wide ascii
        $lenh5 = "wmic shadowcopy delete" wide ascii
        $lenh6 = "bcdedit /set {default} bootstatuspolicy ignoreallfailures" wide ascii
        $lenh7 = "bcdedit /set {default} recoveryenabled no" wide ascii
        $lenh8 = "wbadmin delete catalog -quiet" wide ascii

        //Cong cu nen du lieu
        $zip1 = "inflate 1.1.3 Copyright 1995-1998 Mark Adler" wide ascii
        $zip2 = "unzip 0.15 Copyright 1998 Gilles Vollant" wide ascii
```

Hình 36 Yararule sau khi phân tích và tổng hợp

```

//Ten file
$ten1 = ".wnry" wide ascii nocase
$ten2 = ".wncyr" wide ascii nocase
$ten3 = "taskdl.exe" wide ascii
$ten4 = "taskse.exe" wide ascii
$ten5 = "taskche.exe" wide ascii
$ten6 = "taskhsvc.exe" wide ascii

//Cac file lien quan:
$file1 = "@WanaDecryptor@.bmp"
$file2 = "@WanaDecryptor@.exe.lnk"
$file3 = "@Please_Read_Me@.txt"

//Bitcoin
$ma_bitcoin1 = "115p7UMMMgoj1pMvkpHijcRdfJNXj6LrLn"
$ma_bitcoin2 = "12t9YDPgwueZ9NyMgw519p7AA8isjr6SMw"
$ma_bitcoin3 = "13AM4VWzdhxYgXeQepoHKh5Quy6NGaEb94"

//Url bitcoin
$url_bitcoin1 = "http://www.btcfrog.com/qr/bitcoinPNG.php?address=%s"
$url_bitcoin2 = "https://en.wikipedia.org/wiki/Bitcoin"
$url_bitcoin3 = "https://www.google.com/search?q=how+to+buy+bitcoin"

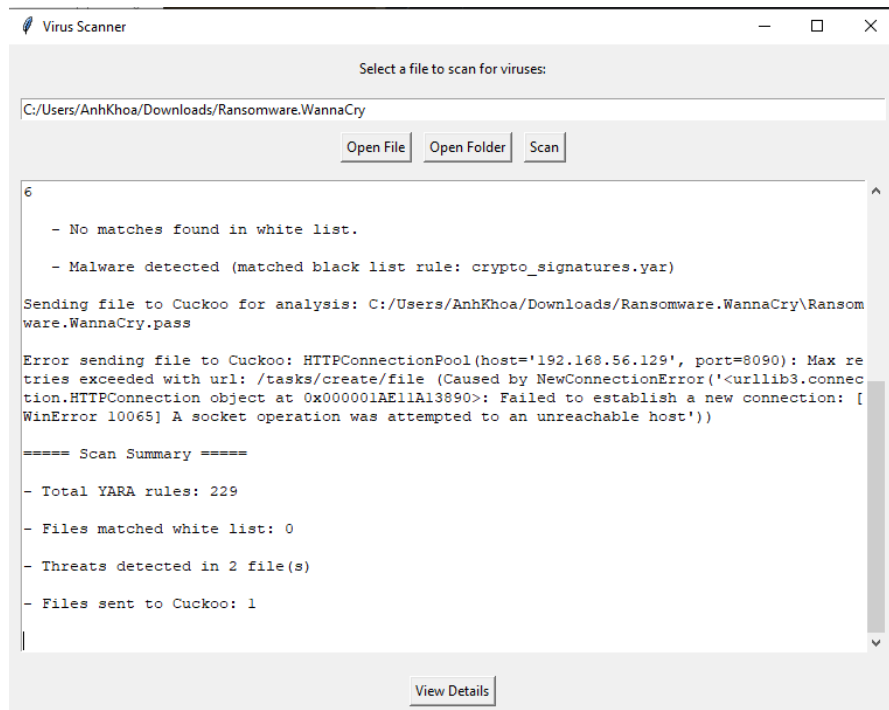
//Mutex
$mutex1 = "Global\\MsWinZonesCacheCounterMutexA"

condition:
(
  (
    (uint16(0) == 0x5A4D)
  )
  and
  (
    (all of ($file*))
    or
    ($mutex1 and (1 of ($string*)))
    or
    (1 of ($ma_bitcoin*))
    or
    (4 of ($lenh*))
    or
    ((1 of ($string*)) and (1 of ($lenh*)))
    or
    ((3 of ($comment*)) and (1 of ($lenh*)))
    or
    ((1 of ($string*)) and (1 of ($ten*)))
    or
    ((1 of ($string*)) and (all of ($url_bitcoin*)))
    or
    ((1 of ($string*)) and (2 of ($zip*)))
  )
)
}

```

Hình 37 Yararule sau khi phân tích và tổng hợp

Cập nhật yara rule vừa viết vào cơ sở dữ liệu và quét lại file unknow.exe một lần nữa, ta thấy ứng dụng đã phát hiện được file unknow là mã độc:



Hình 38 Quét lại file Unknown

TÀI LIỆU THAM KHẢO

- [1] <https://cuckoosandbox.org/>
- [2] <https://yara.readthedocs.io/en/stable/writingrules.html>
- [3] <https://github.com/OpenSecureCo/Demos/blob/main/Cuckoo%20Install>
- [4] <https://www.virustotal.com/>
- [5] <https://www.malwarebytes.com/wannacry>
- [6] <https://www.packetlabs.net/posts/what-are-yara-rules/>
- [7] <https://evasions.checkpoint.com/src/Evasions/index.html>
- [8] Malware Analyst's Cookbook, Practical Malware Analysis